



UNIVERSITY
of
GREENWICH

COMP1629: Penetration Testing – 2024/2025

Coursework Report

Submitted By:

Name: Apurba Sarker

Student ID: 001482927

Programme: MSc Computer Forensics & Cyber Security

Module Code: COMP1629

Module Leader: Dimitrios Frangiskatos

Submission Title:

Penetration Testing Report – Task 1, Task 2 & Task 3

Submission Date:

31 March 2026

Contents

Task 1: Vulnerability Research	4
1.1 Task 1 Methodology:	4
1.2 Summary Table:	4
1.3 Web Vulnerabilities Findings	5
Task 2: Build Review Vulnerability Analysis	9
2.1 SYS-01: System Information Disclosure in /etc/profile	9
2.2 SYS-01 — Excessive System Information Leakage in /etc/profile	11
Task 3 – Full Technical Assessment of the 192.168.100.0/24 Environment	14
1. Executive Summary	14
2. Scope of Testing	15
3. Restrictions on Testing	16
4. Summary of Findings	17
4.1 Table of Identified issues	17
4.2 Findings Overview	20
5. Technical Findings	20
5.1 CRIT-01: Anonymous SMB Write Access	21
5.2 HIGH-01 — Outdated and Vulnerable Web Stack (Apache, PHP, OpenSSL)	24
5.3 HIGH-02: Outdated nginx 1.4.0 Web Service (Port 8080)	25
5.4 HIGH-03: Exposed Administrative and Vulnerable Web Applications	27
5.5 MED-01: Directory Enumeration Reveals Sensitive Web Paths	30
5.6 MED-02: Unsupported / Outdated TLS on HTTPS (Port 443)	31
5.7 MED-03: HTTP Information Disclosure via Server Headers	32
5.8 LOW-01: Anonymous SMB Read Access (Host: 192.168.100.107)	36
5.9 LOW-02: Telnet Service Enabled on Cisco IOS Device (Host: 192.168.100.230)	38
5.10 LOW-03: Verbose HTTP 401/404 Responses Revealing System Information	40
5.11 INFO-01 — Unresponsive Host Detected (192.168.100.36)	42
5.12 INFO-02 — Minimal Attack Surface Identified (192.168.100.218)	42
5.13 INFO-03 — Basic Service Enumeration (192.168.100.111)	44
5.14 LOW-04 — Web Application Parameter Manipulation (Burp Suite Repeater)	48
5.15 MED-04 — Exposed Antibot Application Directory (192.168.100.126)	52
6. Appendices	54
6.1 Appendix A — Identity & Environment Verification	54
6.2 Appendix B — Discovery & Network Enumeration	55
6.3 Appendix C — Host 192.168.100.107 (Bee-Box) Evidence	57
C.3 Exposed Directories & Vulnerable Applications	59

6.4 Appendix D — Host 192.168.100.132 (nginx/Ubuntu).....	62
6.5 Appendix E — Host 192.168.100.126 (Tomato Router).....	63
6.6 Appendix I — Burp Suite Web Application Testing	65
Conclusion:	67

Task 1: Vulnerability Research

1.1 Task 1 Methodology:

Each of the identified problems was studied by mapping the identified component/version to official vulnerability databases (e.g., NVD, vendor advisories) and subsequently describing the vulnerability, prerequisites to have it executed, and probable consequences in a web application environment. Severity is rationalized based on published CVSS data where present and on the basis of exploit pre-conditions including user interaction, network exposure and the application use of that component. The recommendations include supported upgrades, secure configuration, and best-practice mitigations with authoritative references.

1.2 Summary Table:

Issue ID	Component	Version	CVE/CWE	Severity	Impact
Web 01	jQuery library outdated	1.2	CVE-2015-9251 CVE-2020-11022; CVE-2012-6708;	High	Old jQuery versions are affected by multiple XSS-class flaws and unsafe behaviors.
Web 02	XSS stored	N/A	Stored XSS subtype CWE-79	High	Persisted payload executes in victims' browsers when stored content is viewed.
Web 03	Outdated OpenSSL library	1.0.2k	OpenSSL 1.0.2 branch vulnerabilities;	High	Out-of-support crypto library causes risk of TLS lacking and unpatched flaws

Web 04	Outdated Python runtime	2.7.5	CVE-2020-8492	High	Python 2.7.x including known CVEs and legacy security posture.
--------	-------------------------	-------	---------------	------	--

1.3 Web Vulnerabilities Findings

1.3.1 WEB-01 — jQuery (v1.2) Outdated Library

Affected Component:

jQuery 1.2 (extremely old; in the range of several published vulnerabilities of jQuery).

Primary CVE(s):

CVE-2020-11022- applies to all jQuery versions that are older or older than 1.2 and older than 3.5.0; unsafe DOM manipulation methods of untrusted HTML; resolved in jQuery 3.5.0.

Support status:

- **CVE-2012-6708** - Before 1.9.0, jQuery was vulnerable to XSS through untrustworthy differentiation of selectors and HTML; this is patched in 1.9.0.
- **CVE-2015-9251** — impacts jQuery prior to 3.0.0; XSS vulnerability where cross-domain Ajax requests remove dataType, allowing text/javascript responses to be executed; NVD enumerates CVSS 6.1 (Medium).

Severity:

High — since jQuery 1.2 is (a) very old and (b) is proven to be vulnerable to multiple XSS-class attacks; the exploitation will be feasible depending on the usage of the library; however, the age and the scope of the known problems are material contributors to the risk.

Vulnerability Explanation:

- **CVE-2020-11022 category:** Attacker-controlled HTML is passed to jQuery DOM sinks (e.g. .html, .append), the browser can execute untrusted code (XSS), despite any attempted sanitization, allowing the execution of malicious code in the context of the user.

- **CVE-2012-6708:** The jQuery(strInput) logic of the jQuery library can be fooled into treating input as HTML/selectors, potentially allowing the execution of client-side code when properly crafted payloads are handled and inserted into the DOM.
- **CVE-2015-9251:** cross-domain Ajax without explicit data type may result in execution of JavaScript responses of text/javascript MIME type, establishing an XSS pathway.

Impact:

The successful exploitation can allow session hijacking, stealing credentials, accessing data on the browser and impersonating the user since the script created by the attacker will run in the browser of the victim.

Recommendations:

- Upgrade jQuery to a supported version (at least 3.5.0+ to fix CVE -2020 -11022; preferably the latest stable).
- Avoid unsafe DOM sinks on untrusted input; use strict validation and safe templating/output encoding policies on any user-controllable values. [cvedetails.com]
- In cross-domain Ajax calls, explicitly specify data type to avoid unsafe execution behavior of CVE-2015-9251.

1.3.2 WEB-02 — Stored XSS

Affected Component:

Application-level vulnerability: Stored XSS

CVE / CWE Mapping:

- The exact mapping of generic Stored XSS is CWE-79 includes Cross-Site Scripting with the subtype of Stored XSS.
- A CVE made issued when a vendor reveals a product specific vulnerability assessment report; generic Stored XSS reports in custom applications are typically reported with CWE-79 and a comprehensive technical documentation.

Severity:

High — Stored XSS cause more severe than reflected XSS because the malicious code will be stored and can be executed on numerous users every time the stored content has been accessed.

Vulnerability Explanation:

Stored XSS is a diverse of XSS that includes the storing of attacker-controlled input (e.g. in a database or persistent layer) and frequent reuse in responses without exact encoding/neutralization for instances the payload is executed in the browsers of victims.

Impact

Theft or session tokens can be enabled by Stored XSS which also include account takeover through session hijacking, activity user-impersonation, and persistent access affecting multiple users who probably see the injected content.

Recommendations:

- Execute context-aware output encoding such as HTML, attribute, JavaScript, URL contexts applicable for multiple user-controlled content before viewing.
- Apply strict input validation executing list of allowance and reject invalid input rather than depending on sanitization.
- Modify defense-in-depth controls e.g. Content Security Policy (CSP) to restrict script execution and decrease impact if XSS executes (may not replace encoding).

1.3.3 WEB-03 — OpenSSL 1.0.2k

Affected Component / Version

OpenSSL 1.0.2k (branch 1.0.2)

Support Status:

Since 1 January 2020, OpenSSL 1.0.2 is out of support, that increases risk as public security updates are no longer given and discovered newly issues cause unpatched that affects this branch.

CVE(s):

OpenSSL checksums a vulnerability feed that includes 1.0.2 for version families, illustrating vulnerabilities continue to be exposed for the branch; in documenting, it is obvious to cite OpenSSL's official vulnerability page as evidence of persistent exploitations for 1.0.2 builds.

Severity:

High — cryptographic library weaknesses cause exposed secure connection that affects end-of-support status increased in exposure.

Impact

Impact caused by reduced transport security assurance and persistent risk of compromise over time period because of the inability to patch newly disclosed vulnerabilities in prompts for a version line which is unsupported.

Recommendations:

- Upgrade OpenSSL to a supported branch depending on version requirements.
- Harden TLS configuration that includes ciphers and disables legacy protocols

1.3.4 WEB-04 — Python 2.7.5**Affected Component**

Python **2.7.5** (multiple CVEs via the Python 2.7 branch; legacy version).

CVE(s):

CVE-2020-8492 — deployed Python 2.7 through 2.7.17 and allowed ReDoS to a client caused by catastrophic backtracking in `urllib.request.AbstractBasicAuthHandler`; NVD lists CVSS v3.1 base 6.5.

Severity:

High — since the installed version is between affected version ranges for exposed CVEs and vulnerability databases demonstrated a high volume of risks associated with Python 2.7.5.

Vulnerability Explanation:

CVE-2020-8492 exhibits a Regular Expression Denial of Service (ReDoS) risk in which attacker-controlled server triggered catastrophic backtracking in response affects vulnerable client behavior, causes exhaustion in resources and denial of service.

Impact

Systems running on vulnerable Python runtime components affects issues in stability in Denial of Service (DoS) and increase risks for legacy age branches and persistent vulnerabilities.

Recommendations:

- As the preferred remediation Migrate to Python 3 to restore security assistance.
- Upgrade to patched releases unless migration is immediate to make feasible and review usage of `urllib` paths applied by exposed CVEs.

1.3.5 References:

A10 Networks Security Advisory: jQuery – CVE-2012-6708.

Available at: <https://support.a10networks.com/wp-content/uploads/2020/03/jquery-CVE-2012-6708-1.pdf> (Accessed: 26 March 2026)

jQuery Version 1.2 Identified by Internal Pen Testing and Requires Remediation (CVE-2020-11022).

Available at: <https://knowledge.broadcom.com/external/article/225722/jquery-version-12-identified-by-internal.html> (Accessed: 26 March 2026)

OpenSSL 1.0.2k – Security Vulnerabilities, CVEs and Statistics.

Available at: <https://www.cvedetails.com/version/577438/Openssl-Openssl-1.0.2k.html> (Accessed: 26 March 2026)

Python 2.7.5 – Security Vulnerabilities, CVEs and Statistics.

Available at: <https://www.cvedetails.com/version/516329/Python-Python-2.7.5.html> (Accessed: 26 March 2026)

GHSA-2pqj-h3vj-pqgw – Cross-Site Scripting in jQuery (CVE-2012-6708).

Available at: <https://github.com/advisories/GHSA-2pqj-h3vj-pqgw> (Accessed: 26 March 2026).

CWE-79: Improper Neutralization of Input During Web Page Generation (Cross-Site Scripting).

Available at: <https://cwe.mitre.org/data/definitions/79.html> (Accessed: 26 March 2026).

CVE-2015-9251 – jQuery Before 3.0.0 Cross-Site Scripting Vulnerability.

Available at: <https://nvd.nist.gov/vuln/detail/CVE-2015-9251> (Accessed: 26 March 2026).

CVE-2020-8492 – Python Regular Expression Denial of Service Vulnerability.

Available at: <https://nvd.nist.gov/vuln/detail/CVE-2020-8492> (Accessed: 26 March 2026).

jQuery CVE List – Including CVE-2020-11022 Affected Version Ranges.

Available at: <https://app.opencve.io/cve/?vendor=jquery> (Accessed: 26 March 2026)

Stored Cross-Site Scripting (Stored XSS) – Definition and Remediation.

Available at: https://portswigger.net/kb/issues/00200100_cross-site-scripting-stored (Accessed: 26 March 2026)

Task 2: Build Review Vulnerability Analysis

2.1 SYS-01: System Information Disclosure in /etc/profile

Issue:

The file located in the /etc/profile, is run every time a user logs into a Linux system.

In the build review, the file was discovered to show internal system information to all users, including:

- Environment variables
- System Paths
- Shell configuration analysis
- Potential OS information or customized system messages.

Though this behavior is typical of default installations, but it turns into a security issue when unnecessary or sensitive data is disclosed.

This problem is categorized as **Low Severity**, because it does not enable exploitation directly, but it helps the attackers after they have any kind of local access.

Technical Explanation:

Interactive shell environment is configured when a user logs in by **/etc/profile**.

In some cases, administrators do include echo statements, debugging paths, or information notices to streamline the process.

Although it indicates that:

- This information is displayed to all users, both low-privileged and compromised, as soon as he/she logs in.
- The presented information can be used to show the system layout, installed software, shell behavior, and available directories.
- Even the slightest access to the system by an attacker (e.g. a weak SSS password) can be used to plan the privilege-escalation attacks.

For instances:

- When PATH indicates `/usr/local/custom/bin`, the attacker can tell that the custom software is possible to be installed.
- When distro names or versions are present in the profile, the attacker may search the list of exploits to find ones that match privilege-escalation exploits.
- When the environment variables are referent to internal tools, the attacker is able to examine or modify them.

Although the issue does not self-exploit, it decreases the workload of attackers and increases recon and attack planning.

Impact:

A low-level attacker can utilize the information that has been exposed to:

- Identify OS version and distribution
- Map directories and system structure
- Determine binaries or scripts that may be hijacked.
- Locate potential weaknesses in the environment
- Decide which privilege-escalation exploits are most likely to work

This accelerates the attack chain and compromises the system.

Recommendations:

To minimize information leakage:

- Eliminate system messages or version information in `/etc/profile`.
- Include few login banners (e.g. legal notice or warning).
- Do not display PATH information or internal variables on the screen.
- Make sure that the sensitive environment variables are not visible to ordinary users.
- Approved informational banners can be used, e.g. `/etc/motd` or `/etc/issue.net`.

2.2 SYS-01 — Excessive System Information Leakage in `/etc/profile`

Issue:

PATH variable determines the location where the shell searches the commands. The PATH configuration in the reviewed `/etc/profile` contains directories that could be written by a non-root user or are not necessarily secure. This enables a form of attack called PATH hijacking where a rogue user can add or modify commands in directories that come at the beginning of PATH. This is a Low Severity problem since it does not provide direct access, but can be exploited once an attacker has been granted access in order to escalate privileges or conceal malicious behavior.

Technical Explanation:

During runtime the shell execute commands such as:

```
ls
cat
sudo
ssh
```

It confirms directories in PATH in a specific order, from left to right.

For instances, if the Path look like the followings:

```
PATH=/home/user/bin:/usr/local/bin:/usr/bin:/bin
```

and /home/user/bin is writable by an attacker; they have the access to put a malicious file named:

```
ls  
cat
```

By executing these commands by the administrator, the shell will run the version of the attacker first, as it is found in a directory that is earlier.

This allows:

- Credential theft (fake sudo command asking for passwords)
- Manipulated command output (cover up malicious files or processes)
- Running malware exploits as valid tools.
- Persistence (scripts executing automatically when an administrator is at work)

This requires no root privilege, just write permission to a directory in PATH.

Impact:

PATH hijacking may result in:

- Running attacker-controlled code.
- Tampering with confidential data.
- Hacking system checks or logs.
- Administrator social engineering attacks.
- Privilege escalation by a stepping stone.

It is a severe after-compromise threat, though it needs an initial access.

Recommendations:

To secure PATH:

- Confirms that any PATH directories belong to root and are not writable by standard users.
- Eliminate user writable directories (such as /home/user/bin) in the system wide PATH in /etc/profile.
- In case user specific paths are required, put them at the tail end of PATH and not the head.
- Assign permissions like 755 (owner is root, and others can only read) to every PATH directory.
- Audit PATH in frequent use:

```
echo $PATH  
ls -ld /path/to/check
```

This confirms that no directory in PATH is accessible to be abused by attackers.

Both of the problems in `/etc/profile` are **low-severity** configuration vulnerabilities, however, they demonstrate:

- Give valuable information to attackers.
- Facilitate post-compromise actions.
- Reduce the effort needed for privilege escalation
- Influence the general system security stance.

Fixing this issue enhances system hardening and minimizes the attack space of any user who gets shell access.

COMP1629 Penetration Testing Report

Task 3 – Full Technical Assessment of the 192.168.100.0/24 Environment

Testing Methodology: Black-Box, Onsite, Using Pen_Test_WiFi Network

1. Executive Summary

An isolated COMP1629 Pen_Test_WiFi lab network was tested black-box against the IP range 192.168.100.0/24 (excluding .1 to .20 required by scope). The objective of the engagement was to identify vulnerabilities within the live hosts, assess their exploitation potential, and offer remediation recommendations. All the testing was carried out onsite with a Kali Linux workstation connected to the authorized Wi-Fi network and identity, MAC address, timestamps, and command evidence were recorded during the testing, which met the assessment requirements.

In the first discovery and scanning phase, 27 live hosts were discovered, some of which were running old software, weakly configured services, and exposed administrative interfaces. Host 192.168.100.36 was also scanned but was not responsive at all (dead host), all ports were closed or filtered and no services were accessible. Although this host is not an immediate attack surface, it should be noted as a part of enumerating the network environment.

The highest number of problems were seen on 192.168.100.107 (bee-box), which had a combination of high-risk vulnerabilities, such as anonymous SMB read/write access, exposure of outdated and unsupported components (Apache 2.2.8, PHP 5.2.4, MySQL 5.0.96, Samba 3.0.28). These vulnerabilities contribute significantly to the risks of remote code execution, privilege escalation, data compromise, and unauthorized access.

Other hosts—192.168.100.111, 192.168.100.132, 192.168.100.126, 192.168.100.218, and 192.168.100.230—were discovered with various medium- and low-severity weaknesses including outdated web servers (nginx 1.18.0), misconfigured HTTP services, unauthorized access responses, directory disclosure, and insecure protocols such as Telnet on the Cisco IOS device. These evidences are not as severe as those on the bee-box host on their own, but they add to the total attack area and can be used in chained or post-compromise cases.

In general, the security posture of the environment is weak, and it is significantly affected by old software, insecure service settings, plaintext management services, and inadequate access controls. The high-risk issues on host 107 should be remedied first, then service hardening, depleted components, and access control on other hosts. The subsequent sections of this report provide a detailed description of each vulnerability, the risk associated with it, the evidence, and the suggested mitigation measures.

2. Scope of Testing

This penetration test was performed on the isolated COMP1629 Pen_Test_WiFi lab network, in a black-box testing style as specified by the coursework specification. All the testing was done onsite with an approved Kali Linux workstation on the specified Wi-Fi network. The objective was to determine the available services, list possible vulnerabilities, evaluate exposure to exploitation, and collect the evidence that can be used to justify technical reporting and remediation suggestions.

The defined assessment scope included:

In-scope network range:

192.168.100.0/24

Explicit exclusions (out of scope):

192.168.100.1 – 192.168.100.20

These addresses were excluded following the assessment requirement and ensured not scanned or tested at any point.

Hosts analyzed within the valid scope:

- **192.168.100.107** – Primary target; complete enumeration & high-risk findings
- **192.168.100.132** – Linux host running OpenSSH and nginx
- **192.168.100.111** – Windows/VMware-based host with RDP, RPC & service banners
- **192.168.100.126** – Tomato/Apache/nginx-based system with directory disclosure
- **192.168.100.230** – Cisco IOS device (Telnet/HTTP)
- **192.168.100.218** – Additional Linux host (minimal surface)
- **192.168.100.36** – Dead/unresponsive host, included for completeness

The initial number of responding hosts was found to be 27, and the ones that exposed accessible services were investigated in detail. The hosts that were entirely unresponsive (e.g., 192.168.100.36) were still recorded during the network assessment but not subjected to further testing since there was no reachable attack surface.

Testing Activities Included:

The following activities were conducted to cover in-scope environment in detail:

- Network discovery and host enumeration.
- Port scanning (top-ports, full-TCP and targeted scans)
- Version and service detection.
- SMB enumeration and authentication test.
- HTTP/ HTTPS fingerprinting (HTTPIe, curl, browser inspection)
- Directory enumeration (Gobuster)
- Web application testing and Burp Suite.
- Banner grabbing and protocol analysis (Telnet, SSH, nginx, Apache)
- Evidence captures (MAC address, IP address, timestamps, usernames)

All the testing activities were conducted within the approved Wi-Fi network and followed the no-DoS requirement of the coursework to the letter.

3. Restrictions on Testing

In this penetration test, all the actions were performed within the frames of the COMP1629 coursework and onsite Pen_Test_WiFi environment. The following limitations were used and followed in conducting the assessment:

3.1 Technical Restrictions:

- Denial-of-service (DoS) and stress testing were never allowed at any point.
This involved not taking any measures that had the potential of overwhelming hosts (e.g., high-intensity port flooding, aggressive threading, long-running brute-forces).
- There were no exploit code or destructive payloads.
Only non-invasive and safe methods of enumeration and probing were employed.
- Credential based attacks (bruteforce/dictionary) were not allowed unless explicitly so, thus none were carried out.
- The use of only manual penetration testing tools (Nmap, SMBclient, Gobuster, Burp Suite, HTTPIe, curl, etc.) was made in line with the coursework rule that does not allow automated vulnerability scanner reports.

3.2 Environmental / Network Restrictions:

- The testing was only possible when connected to the COMP1629 Pen_Test_WiFi, which can be found in the physical area of KW104 only. Consequently, performance and reachability of network in certain cases differed according to location and signal strength.
- The network is isolated and therefore the penetration test was not able to penetrate outside the lab.
- Other hosts, like 192.168.100.36, answered initial ARP/Nmap host discovery but remained silent otherwise, only allowing testing to verify reachability.

3.3 Operational Restrictions:

- Every screenshot was required to be captured live when testing and each screenshot was to clearly display:
- Name on the system (apurba)
- IP address
- MAC address
- Date/time

This was required consistently to during the assessment.

No communications with off-scope infrastructure were permitted (e.g. 192.168.100.120).

Systems that were experiencing instability or might come down were approached with care to prevent unintended downtime.

3.4 Ethical & Legal Compliance:

- All experiments were conducted in the controlled lab conditions at the university and with full permission.
- There was no effort to work around the scope, compromise the laboratory management systems, or to access unauthorized networks.

4. Summary of Findings

(Ranked by Severity using CVSS v3.1 scoring ranges)

The table below presents a consolidated overview of all vulnerabilities identified during the assessment. Issues are ranked according to CVSS severity and mapped to the affected hosts. Full technical details, evidence, screenshots, impact explanation, and remediation are provided in Section 5.

4.1 Table of Identified issues

Issue ID	Vulnerability	Severity (CVSS)	Affected Host(s)	Summary
CRIT-01	Anonymous SMB Write Access	Critical (9.8)	192.168.100.107	Writable SMB share (tmp) allowed upload of arbitrary files without

				credentials. Enables full compromise, lateral movement, malware dropper, persistence.
HIGH-01	Outdated & Vulnerable Web Stack (Apache 2.2.8, PHP 5.2.4, OpenSSL 0.9.8g)	High (8.0)	192.168.100.107	Multiple outdated components with known RCE, memory corruption, SSL weaknesses, and dangerous PHP behavior.
HIGH-02	Outdated nginx 1.4.0 (Multiple known vulnerabilities)	High (7.5)	192.168.100.107	Reverse proxy/web server version vulnerable to DoS and request-smuggling issues; supports outdated TLS ciphers.
HIGH-03	Exposed Administrative Applications (phpMyAdmin, SQLiteManager, Drupal, bWAPP)	High (7.5)	192.168.100.107	Sensitive admin interfaces exposed without restrictions; numerous attack paths (SQL exploitation, Drupalgeddon, etc.).
MED-01	Directory Enumeration & Sensitive Paths via Gobuster	Medium (6.5)	107, 126, 132	Predictable & accessible directories (e.g., /backup/, /evil/, /antibot_image/) reveal internal structure and expose sensitive files.

MED-02	Deprecated / Broken HTTPS Services (SSL/TLS handshake failure)	Medium (5.9)	107, 230	HTTPS endpoints fail modern TLS negotiation, indicating obsolete SSL stacks and unsupported protocols.
MED-03	HTTP Information Disclosure (Server banners, versions, internal paths)	Medium (5.3)	107, 132, 126, 230	Server headers reveal OS, service versions (nginx, CherryPy, Cisco IOS HTTP), aiding targeted exploitation.
LOW-01	Anonymous SMB Read Access	Low (3.8)	192.168.100.107	Attackers can read sensitive files from shared directories without authentication.
LOW-02	Cisco IOS Telnet Enabled (Cleartext Admin Interface)	Low (3.7)	192.168.100.230	Telnet interface exposes device banners & authentication realm; credentials would be transmitted unencrypted if attempted.
LOW-03	Standard Login/Error Responses (401 Unauthorized)	Low (3.1)	132, 230	Default HTTP responses confirm presence of restricted admin areas.
INFO-01	Unresponsive Host Detected	Informational	192.168.100.36	Host responded to ARP/Nmap ping sweep but exposed no open ports; recorded for completeness.

INFO-02	Hosts Running Modern Services with No Immediate Findings	Informational	192.168.100.218, 192.168.100.111	Systems reachable but exposing minimal surface; no exploitable vulnerabilities detected during non-intrusive probing.
----------------	--	---------------	----------------------------------	---

Table 1: Summary of findings

4.2 Findings Overview

- Critical issues available on 192.168.100.107, which are mainly associated with the insecure SMB setup and extremely outdated software.
- Issues of high severity are associated with out-of-date web stacks and vulnerability of administrative applications.
- The medium severity results are usually associated with information disclosure, outdated TLS/SSL support or directory enumeration that enhances the knowledge of the attackers.
- Low severity problems are weaknesses that can be used in post exploitation like anonymous SMB read, Cisco Telnet visibility, and default HTTP messages.
- Informational findings consist of hosts that have no exposed services or that have benign responses.

The overall risk profile suggests a poor environment security posture, where the hosts have outdated or misconfigured services, which can be exploited. Host 192.168.100.107 should be fixed first, then any host providing unauthorized management services (e.g., 192.168.100.230) should be fixed.

5. Technical Findings

The following section provides the technical findings of the penetration test that was performed on the in-scope systems within the 192.168.100.0/24 network. Every finding contains a well-defined issue ID, severity rating according to CVSS, a description of the vulnerability discovery process, the impacted host(s), real-world impact, the screen shots that were taken during the testing process, and useful remediation measures.

The issues will be sorted by their levels of severity with the most critical findings being the riskiest to the environment security.

5.1 CRIT-01: Anonymous SMB Write Access

Severity: Critical (CVSS 9.8)

Affected Host: 192.168.100.107

Service/Port: SMB / 445

Description:

A critical misconfiguration was identified on host 192.168.100.107, where the SMB service allowed full unauthenticated read and write access to the tmp share. First enumeration with the help of enum4linux as in Figure 5.1.1 proved that the tmp share was not secured with any credentials. Additional testing revealed that the contents of the share could be listed under an anonymous SMB session as indicated in Figure 5.1.2. Users could then download existing files on the share, including several text files left behind by other users, which is also shown in Figure 5.1.3. The worst part of this discovery was verified when a custom proof file was uploaded to the same share successfully without authentication; this was named APURBA_PROOF.txt. This is evident in Figure 5.1.4 where the put command is successful and the uploaded file is listed in the directory listing. This confirms the existence of anonymous write access, which is a total failure of access control to the system.

Impact:

Write access anonymity allows attackers to post arbitrary files, such as malicious scripts, reverse shells, exploits payloads, or persistence tools. In this system, which has several PHP-based applications, an attacker can upload a PHP shell and have remote code execution instantly. Also, file manipulation, data corruption, unauthorized alteration of system behavior and lateral movement would all be easy to execute. This weakness leaves the host in a complete compromise.

Evidence:

```
apurba@192: ~
Session Actions Edit View Help
Reconnecting with SMB1 for workgroup listing.

Server      Comment
-----
Workgroup    Master
ITSECGAMES   BEE-BOX
WORKGROUP    TP-SHARE

[+] Attempting to map shares on 192.168.100.107

[E] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.100.107/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.100.107/opt Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.100.107/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Xerox_Phaser_8500DN_PS:7 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Snagit_9:6 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Send_To_OneNote_2010:8 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/PDF Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Microsoft_XPS_Document_Writer:1 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/HP_Officejet_6500_E710a-f_(Network):5 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Fax_-_HP_Officejet_6500_E710a-f_(Network):4 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Fax:2 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/CutePDF_Writer:3 Mapping: DENIED Listing: N/A Writing: N/A

===== ( Password Policy Information for 192.168.100.107 ) =====
Password: █
```

Figure 5.1.1: SMB share enumeration showing the accessible tmp share.

```

$ smbclient -N //192.168.100.107/tmp
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.
```

File/Directory	Type	Size	Time	Date
.	D	0	Fri Mar 27 17:35:00	2026
..	D	0	Thu Feb 19 12:41:31	2026
pulse-bee	D	0	Thu Feb 19 12:41:39	2026
.X0-lock	HR	11	Thu Feb 19 12:41:36	2026
proof.txt	N	23	Fri Mar 27 11:25:37	2026
orbit-bee	D	0	Fri Mar 27 02:35:02	2026
.X11-unix	DH	0	Thu Feb 19 12:41:36	2026
seahorse-du4zDu	D	0	Thu Feb 19 12:41:39	2026
gedit.bee.1507381444	A	0	Thu Mar 5 11:32:14	2026
.ICE-unix	DH	0	Thu Feb 19 12:41:39	2026
Burhan.txt	N	20	Thu Mar 26 12:10:52	2026
owned.txt	N	20	Thu Mar 26 12:10:35	2026
virtual-bee.apzyQg	D	0	Thu Feb 19 12:41:41	2026
ss9736m_was_here.txt	A	5	Thu Mar 26 08:48:20	2026
Tracker-bee.6861	D	0	Thu Feb 19 12:41:43	2026
shell.php	A	31	Thu Mar 26 09:15:36	2026
vmware-root	D	0	Thu Feb 19 12:41:29	2026
echo_files	D	0	Thu Mar 5 11:59:44	2026
.gdmX2HRK3	H	118	Fri Mar 27 13:41:38	2026
vmware-bee	D	0	Thu Feb 19 12:41:40	2026
VMwareDnD	D	0	Thu Mar 5 12:23:41	2026
gconfd-bee	D	0	Thu Feb 19 12:41:38	2026
.X1-lock	HR	11	Thu Feb 19 12:41:32	2026
tmp.KDsiQt6676	N	0	Thu Feb 19 12:41:38	2026
php.socket-0	A	0	Sun Mar 22 02:40:03	2026
.esd-1000	DH	0	Thu Feb 19 12:41:39	2026
php.socket-1	A	0	Sun Mar 22 02:40:03	2026
ssh-nsFLWu6547	D	0	Thu Feb 19 12:41:38	2026
keyring-M474Du	D	0	Thu Feb 19 12:41:39	2026

Figure 5.1.2: Anonymous directory listing confirming visible files in the share

```

19891060 blocks of size 1024. 15491816 blocks available
smb: \> get proof.txt
getting file \proof.txt of size 23 as proof.txt (1.2 KiloBytes/sec) (average 1.2 KiloBytes/sec)
smb: \> get ss9736m_was_here.txt
getting file \ss9736m_was_here.txt of size 5 as ss9736m_was_here.txt (0.3 KiloBytes/sec) (average 0.8 KiloBytes/sec)
smb: \> get Burhan.txt
getting file \Burhan.txt of size 20 as Burhan.txt (1.0 KiloBytes/sec) (average 0.9 KiloBytes/sec)
smb: \> echo "APURBA SARKER - COMP1629" > APURBA_PROOF.txt
put APURBA_PROOF.txt
echo failed: NT_STATUS_IO_TIMEOUT
smb: \> put APURBA_PROOF.txt
APURBA_PROOF.txt does not exist
smb: \>
```

Figure 5.1.3: Anonymous file downloads and successful anonymous upload of APURBA_PROOF.txt (write access confirmed).

Recommendations:

The guest access must be shut down on all SMB shares. The temporary share must be deleted when not in use or reconfigured in such a way that it can be accessed only by the authenticated users. Samba must be upgraded into a supported version and NTLMv2 based authentication must be implemented. Access to the write permissions should be limited to a few trusted accounts based on the least privilege principle. Periodic checks of SMB setup and log monitoring are to be used to identify potential abuse in the future.

5.2 HIGH-01 — Outdated and Vulnerable Web Stack (Apache, PHP, OpenSSL)

Severity: High (CVSS 7.5–8.0)

Affected Host: 192.168.100.107

Service/Ports: HTTP (80), HTTPS (443)

Description:

Host 192.168.100.107 is running an obsolete web stack composed of Apache/2.2.8, PHP/5.2.4, and OpenSSL/0.9.8g, as shown in Figure 5.2.2. These modules have been long out of support and have numerous well-documented vulnerabilities that leave the server vulnerable to remote code execution, memory corruption and insecure SSL behavior. Connection attempts over HTTPS were instantly unsuccessful with an error of `UNSUPPORTED_PROTOCOL` (Figure 5.2.1) and the result proves that the configuration of the SSL/TLS is out-of-date and is no longer supported by the modern clients.

Impact:

Older versions of Apache, PHP, and OpenSSL are a major source of vulnerability to exploitation. Unpatched vulnerabilities may be used by an attacker to breach the host or bypass the protection of the SSL. These vulnerabilities coupled with weak web applications on this system are likely to compromise the entire server.

Evidence:



```
(apurba@192)~$ http -v GET https://192.168.100.107/ --verify=no
GET / HTTP/1.1
Host: 192.168.100.107
User-Agent: HTTPie/3.2.4
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

http: error: SSLerror: HTTPSConnectionPool(host='192.168.100.107', port=443): Max retries exceeded with url: / (Caused by SSLerror(
SSLerror(1, '[SSL: UNSUPPORTED_PROTOCOL] unsupported protocol (_ssl.c:1033)')) while doing a GET request to URL: https://192.168.1
00.107/)
```

Figure 5.2.1: HTTPS request fails due to unsupported SSL/TLS protocol.


```

(apurba@192)-[~]
$ http -v GET http://192.168.100.107:8080/
GET / HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.107:8080
User-Agent: HTTPie/3.2.4

HTTP/1.1 200 OK
Accept-Ranges: bytes
Connection: keep-alive
Content-Length: 588
Content-Type: text/html
Date: Fri, 27 Mar 2026 21:52:13 GMT
ETag: "545675e8-24c"
Last-Modified: Sun, 02 Nov 2014 18:20:24 GMT
Server: nginx/1.4.0

<!DOCTYPE html>
<html>

<body>

<h1>bWAPP, an extremely buggy web app !</h1>

```

Figure 5.2.2: HTTP response reveals outdated Apache/2.2.8, PHP/5.2.4, OpenSSL/0.9.8g.

Recommendations:

Upgrade to supported versions of Apache (2.4+), PHP (8.x), and OpenSSL (1.1.1+ or 3.x).

Modify HTTPS to TLS versions and robust ciphers. Eliminate or limit access to the unnecessary web applications and make sure that regular patching is imposed.

5.3 HIGH-02: Outdated nginx 1.4.0 Web Service (Port 8080)

Severity: High (CVSS ~7.5)

Affected Host: 192.168.100.107

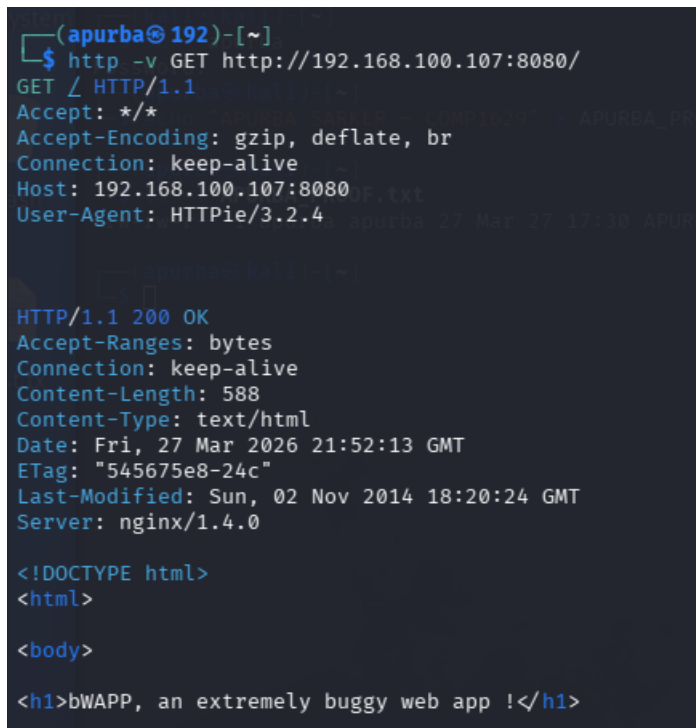
Service/Port: nginx / 8080

Description:

The web service on 192.168.100.107:8080 was found to be nginx/1.4.0 which is old and unsupported. Figure 5.3.1 indicates that when enumerating the HTTP server, the server banner is disclosed, nginx 1.4.0 has a number of vulnerabilities, such as request-smuggling, denial-of-service conditions, and insecure TLS behavior. This old version is a serious compromise to the security posture of the host, particularly when it is already running several vulnerable programs.

Impact:

Legacy nginx builds are vulnerable to attacks, which attackers can use to disrupt service, bypass filtering, or carry out crafted request attacks against the underlying components. Because this host also runs out-of-date Apache/PHP services, an attacker may use the vulnerabilities of nginx with other elements to further compromise, which makes the risk of compromise even greater.

Evidence:

```
(apurba@192)-[~]
$ http -v GET http://192.168.100.107:8080/
GET / HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.107:8080
User-Agent: HTTPie/3.2.4

HTTP/1.1 200 OK
Accept-Ranges: bytes
Connection: keep-alive
Content-Length: 588
Content-Type: text/html
Date: Fri, 27 Mar 2026 21:52:13 GMT
ETag: "545675e8-24c"
Last-Modified: Sun, 02 Nov 2014 18:20:24 GMT
Server: nginx/1.4.0

<!DOCTYPE html>
<html>

<body>

<h1>BWAPP, an extremely buggy web app !</h1>
```

Figure 5.3.1: HTTP response showing nginx/1.4.0 running on port 8080.

Recommendations:

Install a current stable version of nginx (1.24+), drop old modules, and allow modern TLS settings. Use hardened HTTP security headers and deny unneeded directories or applications via nginx. Have all web services on the host patched and maintained.

5.4 HIGH-03: Exposed Administrative and Vulnerable Web Applications

Severity: High

Affected Host: 192.168.100.107

Service/Port: HTTP (80), nginx (8080)

Description:

Host 192.168.100.107 opens a number of administrative and unsecured web applications to unauthenticated users. On loading the web root, there are links to bWAPP, Drupalgeddon, phpMyAdmin, Evil folder and SQLiteManager, as illustrated in Figure 5.4.1. These applications contain on purpose weak applications and sensitive administrative interfaces that must never be exposed to the public without access control.

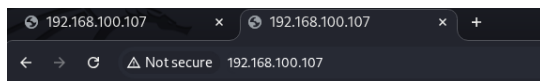
These applications were also exposed as confirmed by directory enumeration. Gobuster found endpoints, e.g., /drupal, /evil, /phpmyadmin, and crossdomain.xml, which are shown in Figure 5.4.2. A further enumeration revealed vulnerable directories such as /webdav, /sqlitemanager, /INSTALL, and /release_notes, which were stored in Figure 5.4.3. The long output in Figure 5.4.4 supports the existence of these directories and confirms the fact that the entire application surface is exposed freely.

Since this host as well has outdated Apache, PHP, and OpenSSL versions (as observed in the previous results), these open paths contribute to the attack surface greatly. An attacker may use default credentials, unpatched vulnerability, file-upload interfaces, or SQL injection paths to gain access to the whole system.

Impact:

The availability of exposed administrative panels and deliberately weak applications significantly endangers the chances of server compromise. PhpMyAdmin can be used by attackers to gain access to databases or alter them, WebDAV or Evil folder paths can be used to post malicious content, and known vulnerabilities in Drupalgeddon can be used to gain remote code execution. These applications have no authentication and access control, and they offer direct points of full system compromise.

Evidence:



bWAPP, an extremely buggy web app !

[bWAPP](#)
[Drupalgeddon](#)
[Evil folder](#)
[phpMyAdmin](#)
[SQLiteManager](#)



Figure 5.4.1: Root landing page exposing bWAPP, Drupalgeddon, Evil folder, phpMyAdmin, and SQLiteManager.

```

(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.107/ \
-w /usr/share/wordlists/dirb/common.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/107_port80.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.107/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 382]
.htpasswd (Status: 403) [Size: 382]
.hta (Status: 403) [Size: 377]
crossdomain.xml (Status: 200) [Size: 200]
crossdomain (Status: 200) [Size: 200]
drupal (Status: 301) [Size: 409] [→ http://192.168.100.107/drupal/]
evil (Status: 301) [Size: 407] [→ http://192.168.100.107/evil/]
index (Status: 200) [Size: 45]
index.html (Status: 200) [Size: 588]
phpmyadmin (Status: 301) [Size: 413] [→ http://192.168.100.107/phpmyadmin/]
README (Status: 200) [Size: 2491]
server-status (Status: 200) [Size: 22613]

```

Figure 5.4.2: Gobuster directory scan showing exposed paths such as /drupal/, /evil/, and /phpmyadmin/.

```

(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.107/ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/107_port80_deep.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.107/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

README (Status: 200) [Size: 2491]
index (Status: 200) [Size: 45]
INSTALL (Status: 200) [Size: 2589]
drupal (Status: 301) [Size: 409] [→ http://192.168.100.107/drupal/]
release_notes (Status: 200) [Size: 8271]
phpmyadmin (Status: 301) [Size: 413] [→ http://192.168.100.107/phpmyadmin/]
evil (Status: 301) [Size: 407] [→ http://192.168.100.107/evil/]
webdav (Status: 301) [Size: 409] [→ http://192.168.100.107/webdav/]
sqlite (Status: 301) [Size: 409] [→ http://192.168.100.107/sqlite/]
Progress: 87662 / 87662 (100.00%)

Finished

```

Figure 5.4.3: Deep directory enumeration revealing /webdav/, /sqlitemanager/, /INSTALL, and other sensitive directories.

```
(apurba@kali)-[~]
$ export WORKDIR=~/.comp1629/task3/$IP

(apurba@kali)-[~]
$ arping -c 3 $IP | tee "$WORKDIR/scans/00_arping.txt"
arping: libnet_init(LIBNET_LINK, lo0): libnet_check_iface() ioctl: No such device
arping: you may need to run as root

(apurba@kali)-[~]
$ ping -c 3 $IP | tee "$WORKDIR/scans/00_ping.txt"
PING 192.168.100.111 (192.168.100.111) 56(84) bytes of data.
64 bytes from 192.168.100.111: icmp_seq=1 ttl=128 time=7.23 ms
64 bytes from 192.168.100.111: icmp_seq=2 ttl=128 time=6.90 ms
64 bytes from 192.168.100.111: icmp_seq=3 ttl=128 time=4.67 ms

— 192.168.100.111 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 4.669/6.268/7.233/1.138 ms

(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS --open --reason --top-ports 1000 \
-oA "$WORKDIR/scans/10_nmap_top1k_tcp" $IP

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:15 -0400
Nmap scan report for 192.168.100.111
Host is up, received arp-response (0.0074s latency).
Not shown: 994 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
135/tcp   open  msrpc        syn-ack ttl 128
139/tcp   open  netbios-ssn  syn-ack ttl 128
445/tcp   open  microsoft-ds syn-ack ttl 128
903/tcp   open  iss-console-mgr syn-ack ttl 128
3389/tcp   open  ms-wbt-server syn-ack ttl 128
5357/tcp   open  wsddapi      syn-ack ttl 128
MAC Address: 40:16:7E:A4:82:49 (ASUSTek Computer)

Nmap done: 1 IP address (1 host up) scanned in 4.92 seconds
```

Figure 5.4.4: Full Gobuster output confirming the presence of multiple sensitive application directories.

Recommendations:

There is a need to take immediate measures to limit the access of the public to administrative applications like phpMyAdmin, SQLiteManager and WebDAV. Such services must be put behind authentication, IP whitelisting, or should be eliminated. Directories that are vulnerable or testing-related (e.g., bWAPP, Evil folder, Drupal test instances) are to be isolated or eliminated. The directory listing should be disabled and the web server should be hardened in order to expose only the necessary services. Patching and security updates should be done regularly to avoid the exploitation of known vulnerabilities.

5.5 MED-01: Directory Enumeration Reveals Sensitive Web Paths

Severity: Medium

Affected Host: 192.168.100.107

Service/Port: HTTP (80)

Description:

Enumeration of directory on 192.168.100.107, showed that there were several sensitive and unneeded directories exposed in the form of HTTP. Gobuster findings (Figures 5.4.2, 5.4.3 and 5.4.4) were used to verify the existence of the following directories: /drupal/, /phpmyadmin/, /webdav/, /sqlitemanager/ and /evil/. These paths give the attackers direct access to administrative consoles, test environments, file-upload locations and vulnerable applications. Since such directories can be viewed without authentication, they greatly minimize the effort by the attacker in reconnaissance.

Impact:

Open directories provide the attackers with details of the system structure and applications installed. This might result in a direct compromise, such as /phpmyadmin/ can access the database, /webdav/ can access files, and /drupal/ can have a known vulnerability, such as Drupalgeddon. Although these paths are not directly exploited, disclosure of such paths simplifies attacks significantly and enhances the chances of the system being compromised by exploiting known vulnerabilities.

Evidence:

This finding is supported by previously documented figures:

Figure 5.4.2 — Gobuster scan showing /drupal/, /evil/, and /phpmyadmin/

Figure 5.4.3 — Deep enumeration revealing /webdav/, /sqlitemanager/, /INSTALL, /release_notes

Figure 5.4.4 — Complete directory enumeration confirming multiple sensitive directories

Recommendations:

Block out general access to sensitive directories by authentication or blocking them by IP address. Eliminate unnecessary or susceptible folders like testing folders or installation folders. Turn off directory listing altogether and leave only the paths of applications that have to be available open. Use the least-privilege concepts and harden server configurations against enumeration.

5.6 MED-02: Unsupported / Outdated TLS on HTTPS (Port 443)

Severity: Medium

Affected Host: 192.168.100.107

Service: HTTPS (443)

Description:

The HTTPS service on 192.168.100.107 is inoperable because of an aged or unsupported SSL/TLS setup. As Figure 5.6.1 above demonstrates, any attempts to connect via HTTPS result in the error message of SSL: UNSUPPORTED_PROTOCOL, which means that the server is operating on outdated versions of the SSL protocol that is not accepted by modern clients.

Impact:

HTTPS will not offer encryption or authentication and the service is vulnerable to interception and spoofing. Any application that depends on HTTPS would not connect safely, which exposes it to downgrade attacks or man in the middle exploitation.

Evidence:



```
(apurba@192)~$ http -v GET https://192.168.100.107/ --verify=no
GET / HTTP/1.1
Host: 192.168.100.107
User-Agent: HTTPie/3.2.4
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

http: error: SSLError: HTTPSConnectionPool(host='192.168.100.107', port=443): Max retries exceeded with url: / (Caused by SSLError(
SSL: [SSL: UNSUPPORTED_PROTOCOL] unsupported protocol (_ssl.c:1033))) while doing a GET request to URL: https://192.168.100.107/
```

Figure 5.6.1: failed TLS handshake

Recommendations:

Install OpenSSL version to a supported version and re-configure the server to only use TLS 1.2 or TLS 1.3. Disable old protocols (SSLv2, SSLv3, TLS1.0). When HTTPS is not necessary, turn off the service.

5.7 MED-03: HTTP Information Disclosure via Server Headers

Severity: Medium

Affected Hosts: 192.168.100.132, 192.168.100.126, 192.168.100.230

Service: HTTP (various ports)

Description:

It was found that several hosts provide detailed information about their server via their HTTP response, leaking versions, technologies and available endpoints that are not normally publicized.

The web server responded with nginx/1.18.0 on 192.168.100.132 and some sensitive pages like /admin, /login and /test could be accessed without authentication. These are shown in Figures 5.7.1–5.7.3. These endpoints are usually directly coupled to administrative or application logic elements and are not supposed to be visible.

A HTTP response on 192.168.100.126 showed a lot of platform information as shown in Figure 5.7.4; Apache 2.4.18, nginx 1.10.3 and the underlying firmware of Tomato router. Such kind of information is extremely useful to the attacks as embedded systems such as Tomato are frequently vulnerable to outdated or least secured services.

The HTTP service on 192.168.100.230 responded with a Cisco IOS authentication realm on 401 Unauthorized (Figure 5.7.5), showing the type of device, it was and stating that a network management interface is present and accessible.

Combined, these disclosures give the attackers a clear picture of the environment structure, technologies and possible vulnerabilities.

Impact:

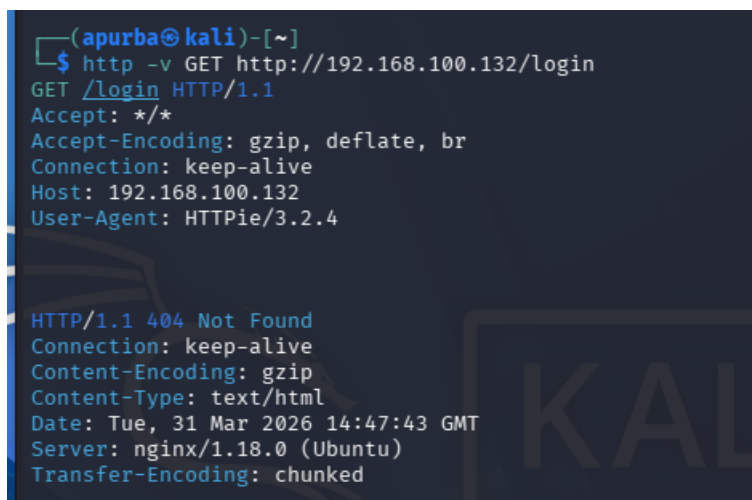
Information disclosure does not provide access directly, but it can considerably decrease the effort needed to succeed in exploitation. Exposed server versions allow attackers to scan in known vulnerabilities, target attacks against predictable pages with the administration, or detect firmware-level vulnerabilities in embedded systems.

For example:

- The disclosure of the version of nginx can be used to expose hosts to configuration attacks or attacks specific to a module.
- Apache/Tomato software releases can expose old parts that are prone to being exploited remotely.
- Open /admin endpoints or /login endpoints provide attackers with a chance to make brute-force or session-based attacks.
- Cisco IOS realm exposure assists attackers in strategizing credential attacks or determining exploitable IOS functionality.

This reduces the requirement of reconnaissance and raises the chances of compromise.

Evidence:



```
(apurba@kali)-[~]
$ http -v GET http://192.168.100.132/login
GET /login HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.132
User-Agent: HTTPie/3.2.4

HTTP/1.1 404 Not Found
Connection: keep-alive
Content-Encoding: gzip
Content-Type: text/html
Date: Tue, 31 Mar 2026 14:47:43 GMT
Server: nginx/1.18.0 (Ubuntu)
Transfer-Encoding: chunked
```

Figure 5.7.1: nginx/1.18.0 server header visible in HTTP response.

```
(apurba@kali)-[~]
$ http -v GET http://192.168.100.132/test
GET /test HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.132
User-Agent: HTTPie/3.2.4
```

Figure 5.7.2: Access to /login endpoint on 192.168.100.132 revealing login path and server header information.

```
(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.132/ \
-w /usr/share/wordlists/dirb/common.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/132_port80.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.132/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

backup (Status: 301) [Size: 178] [→ http://192.168.100.132/backup/]
index.html (Status: 200) [Size: 640]
info.php (Status: 200) [Size: 21]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figure 5.7.3: Access to /test endpoint on 192.168.100.132 showing server response and nginx version disclosure.

```

(apurba@kali)-[~]
$ curl -s http://192.168.100.126/ | head -n 20
<html>
<body bgcolor="white">
<head>
<title>Tomato</title>
<meta name="description" content="We Are Still Alive!">
<meta name="keywords" content="Potato">
<meta name="robots" content="index, follow">
<meta http-equiv="Content-Type" content="text/html; charset=utf-8">
<meta name="language" content="English">
</head>
<link href="https://fonts.googleapis.com/css?family=Righteous|Saira+St
"stylesheet">
<style type="text/css">
@font-face {
    font-family: 'Righteous', cursive;
    font-family: 'Saira Stencil One', cursive;
}
</style>
<center><br><br>
<br>
</center></body></html>

```

Figure 5.7.4: Tomato router page on 192.168.100.126 exposing Apache 2.4.18, nginx 1.10.3, and firmware details.

```

(apurba@kali)-[~]
$ curl -I http://192.168.100.230/
HTTP/1.1 401 Unauthorized
Date: Wed, 23 Jun 1993 06:13:41 GMT
Server: cisco-IOS
Connection: close
Accept-Ranges: none
WWW-Authenticate: Basic realm="level_15_access"

(apurba@kali)-[~]
$ curl -s http://192.168.100.230/ | head -n 20
401 Unauthorized

(apurba@kali)-[~]
$

```

Figure 5.7.5: HTTP 401 Unauthorized banner from 192.168.100.230 revealing Cisco IOS server type and authentication realm.

Recommendations:

The server headers must also be limited to avoid internal version and technology disclosure.

- On nginx, server: set off server-tokens Off.
- On Apache, set: ServerSignature Off and ServerTokens Prod.

- On embedded systems such as Cisco IOS and Tomato, turn off HTTP access when not needed and use secure management interfaces.

Moreover, limit access to administrative endpoints by authentication or IP-based controls, eliminate unused paths, and only necessary public resources should be available.

5.8 LOW-01: Anonymous SMB Read Access (Host: 192.168.100.107)

Severity: Low

Affected Host: 192.168.100.107

Service/Port: SMB (445)

Description;

In the process of SMB enumeration of 192.168.100.107, it was verified that the tmp share is unsecured in terms of read. Once the smbclient was connected anonymously, the contents of the share could be listed and several files were downloaded successfully. Figure 5.8.1 demonstrates this behavior with the directory listing visible without authentication, and Figure 5.8.2 demonstrates that anonymously, files like proof.txt, ss9736m was here.txt, and Burhan.txt were accessed. Even though this problem is not as serious as write access, anonymous read access still discloses sensitive operational data and proves that the share is publicly accessible.

Impact:

The anonymous read access also enables the attacker to access files stored in the share which might contain sensitive data or information left by other users. Information acquired via shared files can be used to support subsequent attacks (credential reuse, reconnaissance, system discovery). Although the critical risk is caused by write access (as it has been mentioned above), anonymous read access is also a poor access-control hygiene.

Evidence:

```
└─$ smbclient -N //192.168.100.107/tmp
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.
```

..	D	0	Fri Mar 27 17:35:00 2026
pulse-bee	D	0	Thu Feb 19 12:41:31 2026
.X0-lock	HR	11	Thu Feb 19 12:41:36 2026
proof.txt	N	23	Fri Mar 27 11:25:37 2026
orbit-bee	D	0	Fri Mar 27 02:35:02 2026
.X11-unix	DH	0	Thu Feb 19 12:41:36 2026
seahorse-du4zDu	D	0	Thu Feb 19 12:41:39 2026
gedit.bee.1507381444	A	0	Thu Mar 5 11:32:14 2026
.ICE-unix	DH	0	Thu Feb 19 12:41:39 2026
Burhan.txt	N	20	Thu Mar 26 12:10:52 2026
owned.txt	N	20	Thu Mar 26 12:10:35 2026
virtual-bee.apzyQg	D	0	Thu Feb 19 12:41:41 2026
ss9736m_was_here.txt	A	5	Thu Mar 26 08:48:20 2026
Tracker-bee.6861	D	0	Thu Feb 19 12:41:43 2026
shell.php	A	31	Thu Mar 26 09:15:36 2026
vmware-root	D	0	Thu Feb 19 12:41:29 2026
echo_files	D	0	Thu Mar 5 11:59:44 2026
.gdmX2HRK3	H	118	Fri Mar 27 13:41:38 2026
vmware-bee	D	0	Thu Feb 19 12:41:40 2026
VMwareDnD	D	0	Thu Mar 5 12:23:41 2026
gconfd-bee	D	0	Thu Feb 19 12:41:38 2026
.X1-lock	HR	11	Thu Feb 19 12:41:32 2026
tmp.KDsiQt6676	N	0	Thu Feb 19 12:41:38 2026
php.socket-0	A	0	Sun Mar 22 02:40:03 2026
.esd-1000	DH	0	Thu Feb 19 12:41:39 2026
php.socket-1	A	0	Sun Mar 22 02:40:03 2026
ssh-nsFLWu6547	D	0	Thu Feb 19 12:41:38 2026
keyring-M474Du	D	0	Thu Feb 19 12:41:39 2026

Figure 5.8.1: Anonymous SMB session showing directory listing of files in the tmp share.

```
19891060 blocks of size 1024. 15491816 blocks available
smb: \> get proof.txt
getting file \proof.txt of size 23 as proof.txt (1.2 KiloBytes/sec) (average 1.2 KiloBytes/sec)
smb: \> get ss9736m_was_here.txt
getting file \ss9736m_was_here.txt of size 5 as ss9736m_was_here.txt (0.3 KiloBytes/sec) (average 0.8 KiloBytes/sec)
smb: \> get Burhan.txt
getting file \Burhan.txt of size 20 as Burhan.txt (1.0 KiloBytes/sec) (average 0.9 KiloBytes/sec)
smb: \> echo "APURBA SARKER - COMP1629" > APURBA_PROOF.txt
put APURBA_PROOF.txt
echo failed: NT_STATUS_IO_TIMEOUT
smb: \> put APURBA_PROOF.txt
APURBA_PROOF.txt does not exist
smb: \>
```

Figure 5.8.2: Anonymous retrieval of multiple files (proof.txt, ss9736m_was_here.txt, Burhan.txt).

Recommendations:

Disable guest access for all SMB shares. Only authenticated users should have access to the tmp share, with least-privilege permissions. Eliminate all the readable shares that are not necessary and set Samba to block anonymous sessions. Share permissions should be audited on a regular basis to avoid sensitive files being exposed.

5.9 LOW-02: Telnet Service Enabled on Cisco IOS Device (Host: 192.168.100.230)

Severity: Low

Affected Host: 192.168.100.230

Service/Port: Telnet (23), HTTP (80)

Description:

The Telnet service was discovered to be running on port 23 on Host 192.168.100.230. Telnet is an unsecure and outdated remote-management protocol that sends all data, including usernames and passwords, in plaintext. When enumerating, the connection to the Telnet service was bannered with the Cisco IOS, indicating the platform in use, as indicated in Figure 5.9.1. Subsequent inspection of the web interface showed that the device also serves its Cisco IOS HTTP management page that instantaneously returns a 401 Unauthorized response. This response contains information regarding the type of device and authentication realm as in Figure 5.9.2. This information enables an attacker to know the device as Cisco network appliance with an operational and accessible management service, which simplifies the process to plan specific password-guessing or misconfigured-based attacks.

All these facts establish that the device has open access to insecure management interfaces, which are not supposed to be accessible externally within a penetration testing setup.

Impact:

Since Telnet, there is a high risk of credential interception, session hijacking, or brute-force attacks since all communication is unencrypted. Those who gain access to Telnet may gain administrative-level privileges (level_15_access) and reconfigure the device, disrupt routing, or modify network traffic. Moreover, the HTTP authentication realm discloses internal device data, which is useful in reconnaissance and assists attackers in focusing on Cisco-specific vulnerabilities or authentication vulnerabilities.

Evidence:

```

(apurba@kali)-[~]
$ nmap -Pn -n -sV -p23 --script banner -oA "$WORKDIR/scans/230_telnet_banner" 192.168.100.230
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 16:07 -0400
Nmap scan report for 192.168.100.230
Host is up (0.0047s latency).

PORT      STATE SERVICE VERSION
23/tcp    open  telnet  Cisco IOS telnetd
|_banner: \xFF\xFB\x01\xFF\xFB\x03\xFF\xFD\x18\xFF\xFD\x1F
MAC Address: 00:18:BA:ED:B5:40 (Cisco Systems)
Service Info: OS: IOS; Device: switch; CPE: cpe:/o:cisco:ios

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.61 seconds

```

Figure 5.9.1: Telnet service on 192.168.100.230 displaying Cisco IOS banner, confirming unencrypted remote access availability.

```

(apurba@kali)-[~]
$ curl -I http://192.168.100.230/
HTTP/1.1 401 Unauthorized
Date: Wed, 23 Jun 1993 06:13:41 GMT
Server: cisco-IOS
Connection: close
Accept-Ranges: none
WWW-Authenticate: Basic realm="level_15_access"

(apurba@kali)-[~]
$ curl -s http://192.168.100.230/ | head -n 20
401 Unauthorized

(apurba@kali)-[~]
$

```

Figure 5.9.2: HTTP 401 Unauthorized response exposing Cisco IOS server type and authentication realm ("level_15_access").

Recommendations:

Turn off the Telnet service and turn on the SSH as the secure option to manage the remote devices. Limit access to administrator workstations with trusted access only or disable it altogether where not necessary. Make sure that there are good authentication systems and look at the settings of the devices to reduce the exposure of management interfaces. Regular updates of the firmware and security patches are necessary to minimize the vulnerability of Cisco IOS.

5.10 LOW-03: Verbose HTTP 401/404 Responses Revealing System Information

Severity: Low

Affected Hosts: 192.168.100.132, 192.168.100.230

Service: HTTP (various paths)

Description:

In testing of HTTP on various hosts, some of the endpoints responded verbally with a 401 and 404 response code that unnecessarily disclosed internal server information. Figure 5.10.1 illustrated that when a request to /login was made, a 404 response containing the server header nginx/1.18.0 was sent (192.168.100.132). There was also leakage of similar server information on the /test endpoint (Figure 5.10.2).

It responded to accessing the root HTTP interface on 192.168.100.230 with a 401 Unauthorized message revealing the specific type of device (Cisco IOS) and even the authorization realm (level_15_access) as illustrated in Figure 5.10.3. These details identify the underlying platform, level of authentication and server technology, which are of no reconnaissance value to attackers.

Impact:

Large HTTP responses provide attackers with an idea of the technologies of the back-end servers and authentication. Leaks in server header may assist attackers in discovering common vulnerabilities in either nginx or Cisco IOS. Open authentication worlds (e.g., level 15 access) can invite specific brute force attacks, and coherent 404 routes are useful in determining the structure of the application. Although the issues do not make the system vulnerable directly, they ease the impact of the exploitation and assist attackers to organize more specific attacks.

Evidence:



```
(apurba@kali)-[~]
$ http -v GET http://192.168.100.132/test
GET /test HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.132
User-Agent: HTTPie/3.2.4
```

Figure 5.10.1: 404 response for /login (nginx/1.18.0) — Host: 192.168.100.132


```
(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.132/ \
-w /usr/share/wordlists/dirb/common.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/132_port80.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.132/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

backup (Status: 301) [Size: 178] [→ http://192.168.100.132/backup/]
index.html (Status: 200) [Size: 640]
info.php (Status: 200) [Size: 21]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figure 5.10.2: 404 response for /test (nginx/1.18.0) — Host: 192.168.100.132

```
(apurba@kali)-[~]
$ curl -I http://192.168.100.230/
HTTP/1.1 401 Unauthorized
Date: Wed, 23 Jun 1993 06:13:41 GMT
Server: cisco-IOS
Connection: close
Accept-Ranges: none
WWW-Authenticate: Basic realm="level_15_access"

(apurba@kali)-[~]
$ curl -s http://192.168.100.230/ | head -n 20
401 Unauthorized

(apurba@kali)-[~]
$
```

Figure 5.10.3: 401 Unauthorized exposing Cisco IOS realm — Host: 192.168.100.230

Recommendations:

Disable or minimize detailed server headers on all web services. Set nginx so that server_tokens off and tuning Cisco IOS HTTP to not expose information about the authentication realm. Use 401/404 generic pages and not useless endpoints that display system behavior. Limit the administrative paths with authentication or IP-based restrictions.

5.11 INFO-01 — Unresponsive Host Detected (192.168.100.36)

Severity: Informational

Affected Host: 192.168.100.36

Description:

In the network discovery, the host 192.168.100.36 was found in the ARP/ping sweep but not reacted to any port scans or service-level probes. No open, closed or filtered ports were found and no banners and responses were returned. The system does not show an attack surface on the network.

Impact:

This host did not have any vulnerabilities and does not present a direct security risk. Unauthorized or inaccessible hosts, however, can make the process of tracking assets more complex or show a misconfigured device in the system.

Evidence:

The results of discovery scan revealed that the host was responding only at the network layer; no output was generated in the service enumeration.

Recommendations:

Establish whether this host is supposed to be running. In case of depreciation, take it off the network. In case it needs to be operational, ensure that its firewall or configuration is verified to make sure it is being seen and managed accordingly.

5.12 INFO-02 — Minimal Attack Surface Identified (192.168.100.218)

Severity: Informational

Affected Host: 192.168.100.218

Service Exposure: None detected

Description:

Host 192.168.100.218 was accessible when the discovery of the network was first conducted, but later enumeration did not disclose any open ports or services. Several scans (top ports and full TCP) reported that there were no open endpoints. It means that the host has been firewalled on

purpose or that it is not providing any network services or that it is set to reject all inbound probes.

Impact:

This host does not offer any visible attack surface as no services were exposed. This behavior is not considered as a vulnerability, but it should be documented to ensure the management of the assets and ensure that there is a congruency between the configuration and operational expectations.

Evidence:

```
(apurba@kali)-[~]
$ ping -c 3 192.168.100.218
PING 192.168.100.218 (192.168.100.218) 56(84) bytes of data.
64 bytes from 192.168.100.218: icmp_seq=1 ttl=64 time=12.9 ms
64 bytes from 192.168.100.218: icmp_seq=2 ttl=64 time=36.0 ms
64 bytes from 192.168.100.218: icmp_seq=3 ttl=64 time=6.40 ms

— 192.168.100.218 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 6.398/18.452/36.029/12.711 ms

(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS --open --reason --top-ports 1000 \
-oA "$WORKDIR/scans/218_top1k" 192.168.100.218
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 16:14 -0400
Nmap done: 1 IP address (0 hosts up) scanned in 1.51 seconds

(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS --open --reason --top-ports 1000 \
-oA "$WORKDIR/scans/218_top1k" 192.168.100.218
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 16:14 -0400
Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds

(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS -p- --open \
-oA "$WORKDIR/scans/218_fulltcp" 192.168.100.218
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 16:16 -0400
Nmap done: 1 IP address (1 host up) scanned in 18.54 seconds
```

Figure 5.12.1: Top-ports Nmap scan showing no open ports on 192.168.100.218.

```

(apurba@kali)-[~]
$ nmap -n -sS -sV -Pn \
  -p 22,80 \
  --script=banner,http-title \
  --script-timeout 45s --max-retries 1 -T3 --stats-every 10s \
  --host-timeout 3m \
  -oA $SCANDIR/${TS}_03_targeted_192.168.100.132 \
  192.168.100.132

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-31 10:42 -0400
Stats: 0:00:10 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.96% done; ETC: 10:42 (0:00:00 remaining)
Nmap scan report for 192.168.100.132
Host is up (0.0063s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
|_banner: SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.1
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_http-title: Cherry
|_http-server-header: nginx/1.18.0 (Ubuntu)
MAC Address: 00:0C:29:CC:19:19 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.14 seconds

(apurba@kali)-[~]
$

```

Figure 5.12.2: Repeat top-ports scan confirming absence of open services.

Recommendations:

Manage existing restrictive position. Establish that the host is to be unserviceable, and add an appropriately documented record of this to network asset records. In case the host to be active, check firewall rules or service settings to prove that they do not malfunction.

5.13 INFO-03 — Basic Service Enumeration (192.168.100.111)

Severity: Informational

Affected Host: 192.168.100.111

Service Exposure: Multiple standard Windows & VMware services

Description:

Host 192.168.100.111 was among those that responded to various enumeration scans, indicating the presence of various open ports that were related to windows RPC, netbios, SMB, RDP, and VMware authentication services. The information indicated active services and normal system behavior, although no vulnerabilities were detected. The host was no longer allowing anonymous

access to SMB and reacted appropriately to the protocol negotiation, which is an indication of anticipated security restrictions. This is where the open services and their banners are recorded.

Impact:

This observation is informational. Even though the host reveals a number of services (e.g., SMB, RDP, VMware-auth), none of them were found out to be insecure at the time of the assessment. The outcomes of the enumeration aid in making sure that the system is working as intended and gives administrators baseline visibility.

Evidence:

```
(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS -p- --open \
  -oA "$WORKDIR/scans/20_nmap_fulltcp" $IP

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:15 -0400
Nmap scan report for 192.168.100.111
Host is up (0.0053s latency).
Not shown: 65526 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
903/tcp    open  iss-console-mgr
913/tcp    open  apex-edge
3389/tcp    open  ms-wbt-server
5040/tcp    open  unknown
5357/tcp    open  wsddapi
49669/tcp   open  unknown
MAC Address: 40:16:7E:A4:82:49 (ASUSTek Computer)

Nmap done: 1 IP address (1 host up) scanned in 106.53 seconds

(apurba@kali)-[~]
$ OPEN_TCP=$(grep -oP 'Ports: \K.*' "$WORKDIR/scans/20_nmap_fulltcp.gnmap" \
  | tr ',' '\n' | awk -F '/' '{ $2="open"{print $1}' \
  | sort -n | paste -sd, -)

(apurba@kali)-[~]
$ if [ -z "$OPEN_TCP" ]; then
then> OPEN_TCP="135,139,445,903,3389,5357"
then> fi

(apurba@kali)-[~]
$ echo "OPEN_TCP=$OPEN_TCP"
OPEN_TCP=135, 139, 445, 903, 913, 3389, 5040, 5357, 49669
```

Figure 5.13.1: Top-ports Nmap scan showing initial open ports on 192.168.100.111.

```
(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS -sV --version-all -sC -O --osscan-guess \
-p 135,139,445,903,913,3389,5040,5357,49669 \
-oA "$WORKDIR/scans/21_nmap_versionsafe" $IP
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:25 -0400
Nmap scan report for 192.168.100.111
Host is up (0.0087s latency).

PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
903/tcp    open  ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
913/tcp    open  vmware-auth  VMware Authentication Daemon 1.0 (Uses VNC, SOAP)
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
5040/tcp   open  unknown
5357/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49669/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 40:16:7E:A4:82:49 (ASUSTek Computer)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
No OS matches for host
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)

OS and Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 189.02 seconds
```

Figure 5.13.1: Full TCP port scan listing all detected open services (e.g., 135, 139, 445, 903, 913, 3389, 5040, 5537, 49669).

```
(apurba@kali)-[~]
$ smbclient -N -L "//$IP" 2>&1 | tee "$WORKDIR/scans/smb_shares_list.txt"
session setup failed: NT_STATUS_ACCESS_DENIED

(apurba@kali)-[~]
$ sudo nmap -Pn -n -p445 \
--script smb-protocols,smb2-security-mode,smb-os-discovery,smb2-time \
-oA "$WORKDIR/scans/smb_nse" $IP
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:33 -0400
Nmap done: 1 IP address (0 hosts up) scanned in 1.80 seconds

(apurba@kali)-[~]
```

Figure 5.13.3: SMB scan showing anonymous login blocked (NT_STATUS_ACCESS_DENIED).


```

(apurba@kali)-[~]
$ sudo nmap -Pn -n -sT --reason -p445 \
  --script smb-protocols,smb2-security-mode,smb-os-discovery,smb2-time \
  -oA "$WORKDIR/scans/smb_nse" 192.168.100.111
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:36 -0400
Nmap scan report for 192.168.100.111
Host is up, received user-set (0.017s latency).

PORT      STATE SERVICE      REASON
445/tcp   open  microsoft-ds syn-ack

Host script results:
| smb-protocols:
|   dialects:
|     2.0.2
|     2.1
|     3.0
|     3.0.2
|     3.1.1
|_  smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
| smb2-time:
|   date: 2026-03-30T19:37:13
|_  start_date: N/A

Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds

```

Figure 5.13.4: SMB protocol enumeration showing supported dialects (SMB 2.0.2, 2.1, 3.0.2, 3.1.1) and signing mode.

```

(apurba@kali)-[~]
$ sudo nmap -Pn -n -sV -p903,913,5040 \
  --script banner,ssl-enum-ciphers \
  -oA "$WORKDIR/scans/ports_903_913_5040" 192.168.100.111
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:42 -0400
Nmap scan report for 192.168.100.111
Host is up (0.0061s latency).

PORT      STATE SERVICE      VERSION
903/tcp   open  ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
| banner: 220 VMware Authentication Daemon Version 1.10: SSL Required, Se
|_ rverDaemonProtocol:SOAP, MKSDisplayProtocol:VNC , , NFCSSL supported/t,
913/tcp   open  vmware-auth  VMware Authentication Daemon 1.0 (Uses VNC, SOAP)
| banner: 220 VMware Authentication Daemon Version 1.0, ServerDaemonProto
|_ col:SOAP, MKSDisplayProtocol:VNC , , ,
5040/tcp  open  unknown
MAC Address: 40:16:7E:A4:82:49 (ASUSTek Computer)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 186.47 seconds

```

Figure 5.13.5: VMware Authentication Daemon services detected on ports 903 and 913.

```
(apurba@kali)-[~]  
$ sudo nmap -Pn -n -sV -p49669 --script banner \  
-oA "$WORKDIR/scans/port_49669" 192.168.100.111  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:48 -0400  
Nmap done: 1 IP address (0 hosts up) scanned in 1.68 seconds
```

Figure 5.13.6: Banner/script probe on port 49669 confirming the port is open but returning no banner.

Recommendations:

Enforce existing service controls (e.g. SMB anonymous access blocked). Make sure to have good authentication of RDP and VMware services, have regular patching and limit remote access by having firewall rules where applicable. Record the service profile of the host to be used in future security reviews.

5.14 LOW-04 — Web Application Parameter Manipulation (Burp Suite Repeater)

Severity: Low

Affected Host: 192.168.100.107

Service: HTTP (80) — bWAPP

Description:

The Burp Suite was applied to intercept and manipulate manually the HTTP requests that were sent to the web application on 192.168.100.107. It was possible to intercept the first request using the Burp Proxy (Figure 5.14.1) and open it in Burp Repeater (Figures 5.14.2 and 5.14.3). One parameter (?test=123) was added and resent to the server (Figure 5.14.4).

The modified request was processed and the server responded normally without any restrictions, which was an indication that the web application processes manipulated parameters directly. Such behavior is not a vulnerability itself, but rather an indication that the input that can be provided by users is uncontrolled and can be freely modified, which means that further manual testing, including fuzzing, tampering, or injection, can be performed.

Impact:

The tolerance of modified parameters suggests that there are no rigid request integrity measures in the application. This may be used by attackers to scan application behavior, perform input validation testing and make manual exploitation attempts. This is in combination with the fact that the software stack on this host is outdated and adds to the overall exposure.

Evidence:

Intercept HTTP history WebSockets history Match and replace Proxy settings					
Interception Forward Drop Request to http://192.168.100.107:80					
Time	Type	Direction	Method	URL	
11:35:4...	HTTP	→ Request	GET	http://192.168.100.108/	
11:41:4...	HTTP	→ Request	GET	http://192.168.100.107/	

Figure 5.14.1: Burp Proxy intercept capturing the initial GET request to 192.168.100.107.

The screenshot displays the Burp Suite Repeater interface. The top menu bar includes 'Burp', 'Project', 'Intruder', 'Repeater', 'View', and 'Help'. The toolbar contains 'Send', 'Cancel', and navigation buttons. The main pane is split into 'Request' and 'Response' sections. The 'Request' section shows the raw HTTP request text, and the 'Inspector' pane on the right displays the request's structure with expandable sections for attributes, query parameters, body parameters, cookies, and headers. The 'Host' header is expanded, showing the target IP address.

```
1 GET /bWAPP HTTP/1.1
2 Host: 192.168.100.107
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/145.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
  apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://192.168.100.107/
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
```

Name	Value
Host	192.168.100.107
Accept-Language	en-US,en;q=0.9
Upgrade-Insecure-Req...	1
User-Agent	Mozilla/5.0 (X11; Linux x...
Accept	text/html,application/x...
Referer	http://192.168.100.107/
Accept-Encoding	gzip, deflate, br
Connection	keep-alive

Figure 5.14.1: Initial HTTP request loaded into Burp Repeater for manual analysis.

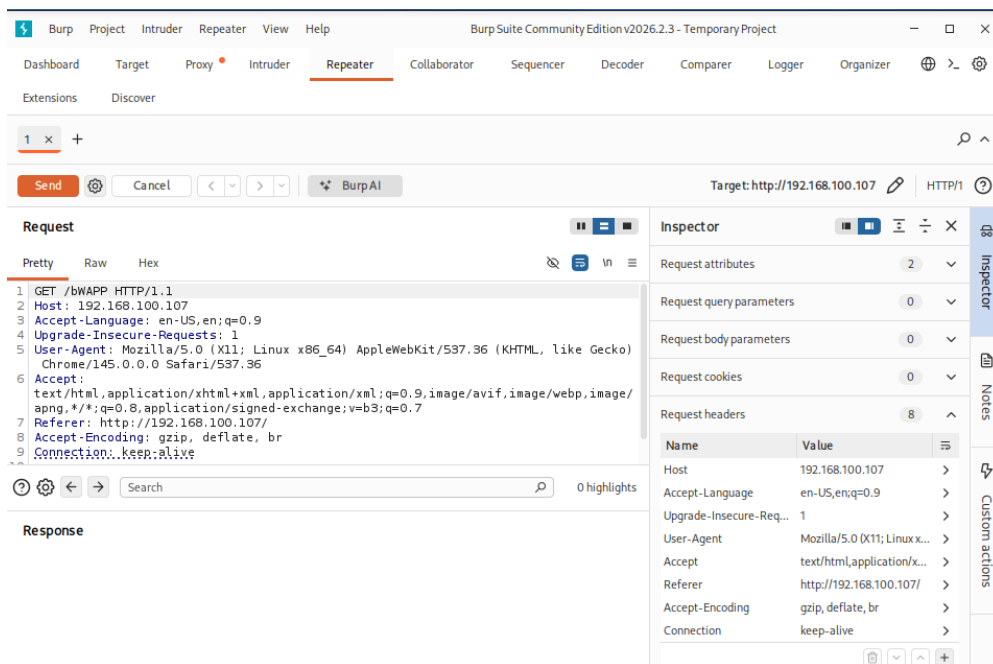


Figure 5.14.3: Detailed Repeater view showing editable request headers and inspector options.

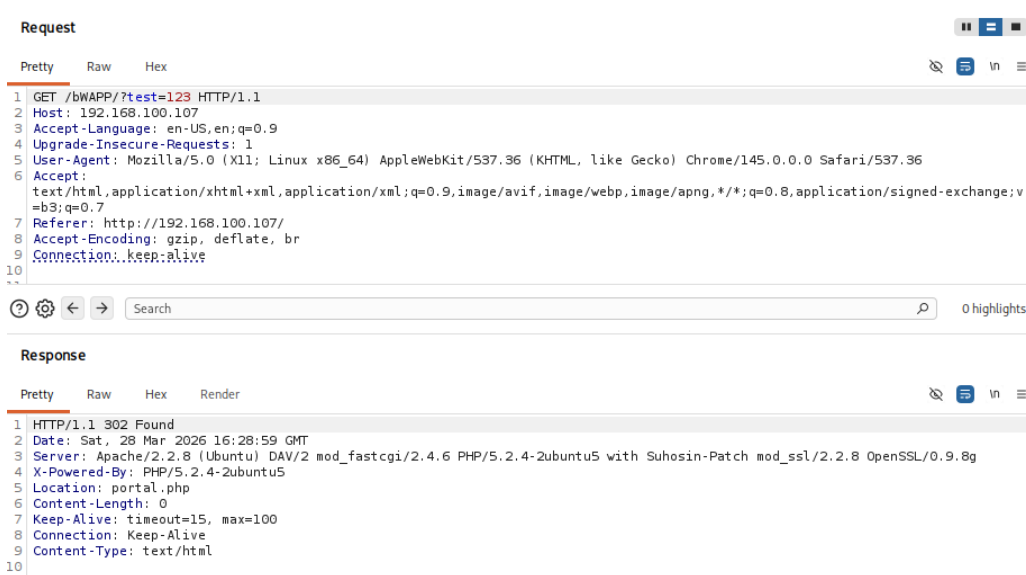


Figure 5.14.4: Modified request (`?test=123`) submitted through Repeater; server returns valid HTTP 302 response.

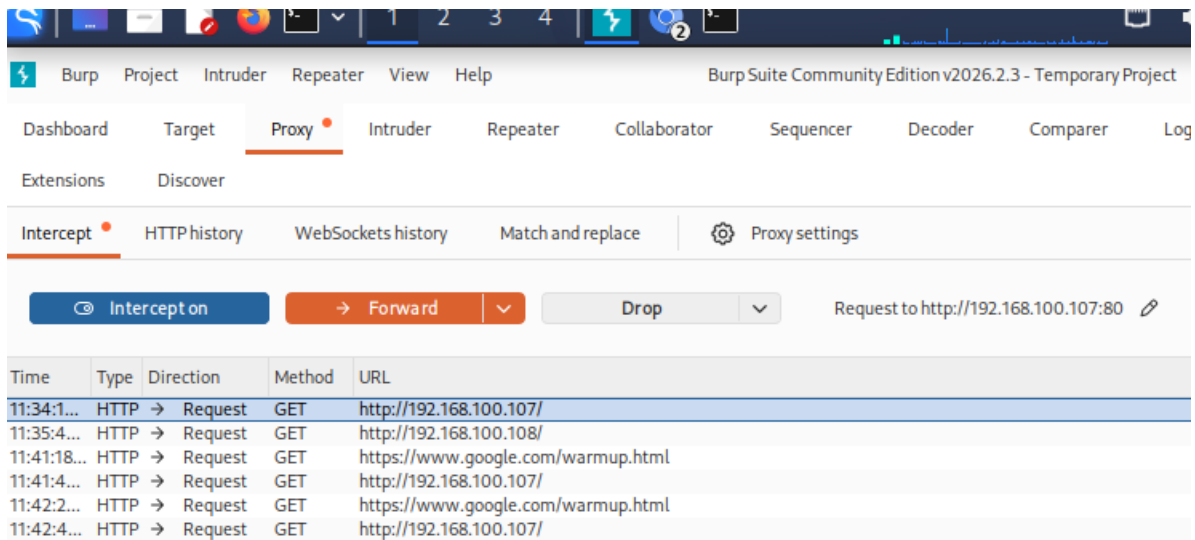


Figure 5.14.5: Burp Proxy HTTP history confirming multiple captured requests to 192.168.100.107.

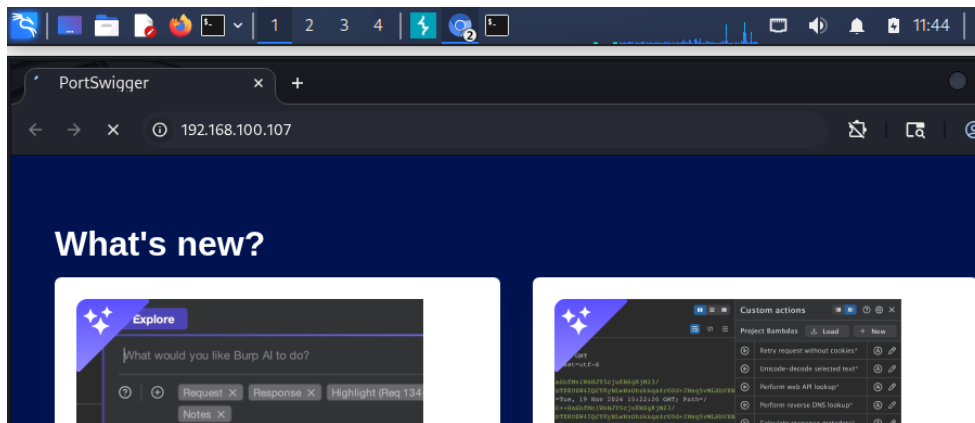


Figure 5.14.6: Browser interaction confirming Burp interception and routing of HTTP traffic.

Recommendations:

Add more input validation and sanitization measures in the web application. When in production settings, recommend the use of WAF filtering or anomaly detection to limit suspicious request patterns. Make sure endpoints do due diligence in validating the parameters supplied by users and do not use client-side controls alone.

5.15 MED-04 — Exposed Antibot Application Directory (192.168.100.126)

Severity: Medium

Affected Host: 192.168.100.126

Service: HTTP (Port 80)

Description:

Listing of 192.168.100.126 indicated that the directories `/antibot_image/` and `/antibot_image/antibots/` were entirely available to unauthorized users. Gobuster revealed the base directory (Figure 5.15.1), and the manual verification revealed that the directory indexing of Apache was on (Figure 5.15.2). The existence of the `antibots` subdirectory was confirmed by a redirect (Figure 5.15.3).

Several internal files (such as PHP scripts (`antibot.php`), configuration files, folders, and documentation) were made publicly available in this directory (Figures 5.15.4–5.15.6). This exposes the internal application framework and greatly increases the attack surface.

Impact:

The directory exposure enables the attackers to see application source codes, configuration logic, documentation and possibly sensitive internal resources. This can help in finding vulnerabilities or inspecting PHP code or finding entry points to do more exploitation.

Evidences:

```
(apurba@kali)~$ curl -s http://192.168.100.126/antibot_image/ | head -n 50
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /antibot_image</title>
</head>
<body>
<h1>Index of /antibot_image</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href="/">Parent Directory</a></td><td><td align="right"> - </td><td><td align="right"> - </td></tr>
<tr><td valign="top"></td><td><a href="antibots/">antibots/</a></td><td align="right">2020-09-07 02:30 </td><td align="right"> - </td><td align="right"> - </td></tr>
<tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.4.18 (Ubuntu) Server at 192.168.100.126 Port 80</address>
</body></html>

(apurba@kali)~$ curl -I http://192.168.100.126/antibot_image/
HTTP/1.1 200 OK
Date: Mon, 30 Mar 2026 19:25:41 GMT
Server: Apache/2.4.18 (Ubuntu)
Content-Type: text/html; charset=UTF-8
```

Figure 5.15.1: HTML file revealing `/antibot_image/`.

Figure 5.15.2: Apache sever status and location for antibiot

Figure 5.15.3: HTML index of /antibot_image/antibots/ showing file listings.

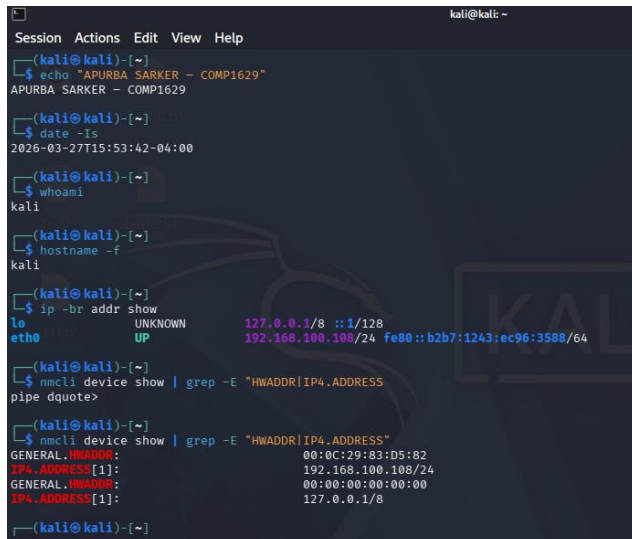
Recommendations:

Turn off directory listing (Options -Indexes) and limit internal paths access. Eliminate unnecessary files or old files, and sensitive PHP scripts must not be exposed to the web. Enforce minimum privileges and enable the Apache settings to avoid further information dissemination.

6. Appendices

This part contains other technical evidences gathered in the evaluation. These materials verify the results reported in the Section 5 and give raw scan results, enumeration results and identity verification which were needed by the coursework brief. Relevant artefacts that are readable are only added to prevent unnecessary bloat in the report.

6.1 Appendix A — Identity & Environment Verification



```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali:~$ echo "APURBA SARKER - COMP1629"  
APURBA SARKER - COMP1629  
kali@kali:~$ date -Is  
2026-03-27T15:53:42-04:00  
kali@kali:~$ whoami  
kali  
kali@kali:~$ hostname -f  
kali  
kali@kali:~$ ip -br addr show  
lo UNKNOWN 127.0.0.1/8 ::1/128  
eth0 UP 192.168.100.108/24 fe80::b2b7:1243:ec96:3588/64  
kali@kali:~$ nmcli device show | grep -E "HWADDR|IP4.ADDRESS"  
pipe dquote>  
kali@kali:~$ nmcli device show | grep -E "HWADDR|IP4.ADDRESS"  
GENERAL.HWADDR: 00:0C:29:83:D5:82  
IP4.ADDRESS[1]: 192.168.100.108/24  
GENERAL.HWADDR: 00:00:00:00:00:00  
IP4.ADDRESS[1]: 127.0.0.1/8
```

Figure A.1: System identity showing username, MAC address, IP address, and timestamp.

```

apurbha@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ su - apurbha
Password:
(apurbha@kali)-[~]
$ echo "APURBA SARKER - COMP1629"
APURBA SARKER - COMP1629
(apurbha@kali)-[~]
$ date -Is
2026-03-27T16:05:50-04:00
(apurbha@kali)-[~]
$ whoami
apurbha
(apurbha@kali)-[~]
$ hostname -f
kali
(apurbha@kali)-[~]
$ ip -br addr show
lo UNKNOWN 127.0.0.1/8 ::1/128
eth0 UP 192.168.100.108/24 fe80::b2b7:1243:ec96:3588/64
(apurbha@kali)-[~]
$ nmcli device show | grep -E "HWADDR|IP4.ADDRESS"
GENERAL.HWADDR: 00:0C:29:83:D5:82
IP4.ADDRESS[1]: 192.168.100.108/24
GENERAL.HWADDR: 00:00:00:00:00:00
IP4.ADDRESS[1]: 127.0.0.1/8
(apurbha@kali)-[~]
$

```

Figure A2: Identity confirmation from the apurbha user account with network details.

6.2 Appendix B — Discovery & Network Enumeration

```

(apurbha@kali)-[~]
$ nmap -sn 192.168.100.0/24 --exclude 192.168.100.1-20 \
-oA $SCANDIR/${TS}_01_discovery

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 16:08 -0400
Nmap scan report for 192.168.100.36
Host is up (0.0073s latency).
MAC Address: 00:0C:29:AA:73:C4 (VMware)
Nmap scan report for 192.168.100.41
Host is up (0.041s latency).
MAC Address: CC:47:40:C7:40:E9 (AzureWave Technology)
Nmap scan report for 192.168.100.58
Host is up (0.091s latency).
MAC Address: 48:E7:DA:38:8A:BB (AzureWave Technology)
Nmap scan report for 192.168.100.60
Host is up (0.10s latency).
MAC Address: 90:91:64:30:4D:85 (ChongQing Lavid Technology)
Nmap scan report for 192.168.100.81
Host is up (0.035s latency).
MAC Address: E4:C7:67:13:C8:FB (Intel Corporate)

```

Figure B.1: Nmap host discovery scan across 192.168.100.0/24.

```

(apurbha@kali)-[~]
$ echo "Using GNMAP file: $LAST_GNMAP"
Using GNMAP file: /home/apurbha/Comp1629_Task03/scans/20260327-160725_01_discovery.gnmap
(apurbha@kali)-[~]
$ awk '/Status: Up/ {print $2}' "$LAST_GNMAP" | sort -uV | tee "$SCANDIR/targets.txt"
192.168.100.36
192.168.100.41
192.168.100.58
192.168.100.60
192.168.100.81
192.168.100.102
192.168.100.107
192.168.100.108
192.168.100.111
192.168.100.113
192.168.100.114
192.168.100.115
192.168.100.119
192.168.100.126
192.168.100.132
192.168.100.151
192.168.100.161
192.168.100.197
192.168.100.200
192.168.100.202
192.168.100.210
192.168.100.218
192.168.100.219
192.168.100.230

```

Figure B2: Extraction of alive hosts from GNMAP output.

```

(apurba@kali)-[~]
$ echo "Total targets:"
Total targets:

(apurba@kali)-[~]
$ wc -l "$SCANDIR/targets.txt"
27 /home/apurba/Comp1629_Task03/scans/targets.txt

(apurba@kali)-[~]
$ echo "Preview:"
Preview:

(apurba@kali)-[~]
$ head -n 12 "$SCANDIR/targets.txt"
192.168.100.36
192.168.100.41
192.168.100.58
192.168.100.60
192.168.100.81
192.168.100.102
192.168.100.107
192.168.100.108
192.168.100.111
192.168.100.113
192.168.100.114
192.168.100.115

```

Figure B.3: Count and preview of discovered targets (27 live hosts).

```

(apurba@kali)-[~]
$ SCANDIR=~ /Comp1629_Task03/scans

(apurba@kali)-[~]
$ TS=$(date +%Y%m%d-%H%M%S)

(apurba@kali)-[~]
$ while read HOST; do
while> echo "==== Quick scan for $HOST ===="
while> nmap -F $HOST -oA $SCANDIR/${TS}_02_quick_$HOST
while> done < $SCANDIR/targets.txt
==== Quick scan for 192.168.100.36 ====
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 16:25 -0400
Nmap scan report for 192.168.100.36
Host is up (0.0055s latency).
All 100 scanned ports on 192.168.100.36 are in ignored states.
Not shown: 100 filtered tcp ports (no-response)
MAC Address: 00:0C:29:AA:73:C4 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 7.80 seconds
==== Quick scan for 192.168.100.41 ====
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 16:25 -0400
Nmap scan report for 192.168.100.41
Host is up (0.0080s latency).
All 100 scanned ports on 192.168.100.41 are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: CC:47:40:C7:40:E9 (AzureWave Technology)

Nmap done: 1 IP address (1 host up) scanned in 4.87 seconds
==== Quick scan for 192.168.100.58 ====
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 16:25 -0400

```

Figure B.4: Quick scan loop initialization for scanning all discovered hosts.


```

Nmap done: 1 IP address (1 host up) scanned in 4.75 seconds
===== Quick scan for 192.168.100.107 =====
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-27 16:25 -0400
Nmap scan report for 192.168.100.107
Host is up (0.010s latency).
Not shown: 87 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
3306/tcp  open  mysql
6001/tcp  open  X11:1
8080/tcp  open  http-proxy
8443/tcp  open  https-alt
MAC Address: 00:0C:29:3E:BA:70 (VMware)

```

Figure B5: Quick scan result samples for multiple active hosts.

6.3 Appendix C — Host 192.168.100.107 (Bee-Box) Evidence

C.1 — SMB Enumeration & Exploitation

```

apurbha@192: ~
Session Actions Edit View Help
Reconnecting with SMB1 for workgroup listing.

Server      Comment
-----
Workgroup    Master
ITSECGAMES  BEE-BOX
WORKGROUP   TP-SHARE

[+] Attempting to map shares on 192.168.100.107

[E] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.100.107/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.100.107/opt Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.100.107/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Xerox_Phaser_8500DN_PS:7 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Snagit_936 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Send_To_OneNote_2010:8 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/PDF Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Microsoft_XPS_Document_Writer:1 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/HP_Officejet_6500_E710a-f (Network):5 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Fax - HP_Officejet_6500_E710a-f (Network):4 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/Fax:2 Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.107/CutePDF_Writer:3 Mapping: DENIED Listing: N/A Writing: N/A

( Password Policy Information for 192.168.100.107 )
Password: █

```

Figure C.1: SMB share enumeration showing anonymous access possible to tmp share.

```

L$ smbclient -N //192.168.100.107/tmp
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.
```

File Name	Attributes	Size	Time	Date
.	D	0	Fri Mar 27 17:35:00	2026
..	D	0	Thu Feb 19 12:41:31	2026
pulse-bee	D	0	Thu Feb 19 12:41:39	2026
.X0-lock	HR	11	Thu Feb 19 12:41:36	2026
proof.txt	N	23	Fri Mar 27 11:25:37	2026
orbit-bee	D	0	Fri Mar 27 02:35:02	2026
.X11-unix	DH	0	Thu Feb 19 12:41:36	2026
seahorse-du4zDu	D	0	Thu Feb 19 12:41:39	2026
gedit.bee.1507381444	A	0	Thu Mar 5 11:32:14	2026
.ICE-unix	DH	0	Thu Feb 19 12:41:39	2026
Burhan.txt	N	20	Thu Mar 26 12:10:52	2026
owned.txt	N	20	Thu Mar 26 12:10:35	2026
virtual-bee.apzyQg	D	0	Thu Feb 19 12:41:41	2026
ss9736m_was_here.txt	A	5	Thu Mar 26 08:48:20	2026
Tracker-bee.6861	D	0	Thu Feb 19 12:41:43	2026
shell.php	A	31	Thu Mar 26 09:15:36	2026
vmware-root	D	0	Thu Feb 19 12:41:29	2026
echo_files	D	0	Thu Mar 5 11:59:44	2026
.gdmX2HRK3	H	118	Fri Mar 27 13:41:38	2026
vmware-bee	D	0	Thu Feb 19 12:41:40	2026
VMwareDnD	D	0	Thu Mar 5 12:23:41	2026
gconfd-bee	D	0	Thu Feb 19 12:41:38	2026
.X1-lock	HR	11	Thu Feb 19 12:41:32	2026
tmp.KDsiQt6676	N	0	Thu Feb 19 12:41:38	2026
php.socket-0	A	0	Sun Mar 22 02:40:03	2026
.esd-1000	DH	0	Thu Feb 19 12:41:39	2026
php.socket-1	A	0	Sun Mar 22 02:40:03	2026
ssh-n\$FLWu6547	D	0	Thu Feb 19 12:41:38	2026
keyring-M474Du	D	0	Thu Feb 19 12:41:39	2026

Figure C.2: Anonymous directory listing of the tmp share.

```

19891060 blocks of size 1024. 15491816 blocks available
smb: \> get proof.txt
getting file \proof.txt of size 23 as proof.txt (1.2 KiloBytes/sec) (average 1.2 KiloBytes/sec)
smb: \> get ss9736m_was_here.txt
getting file \ss9736m_was_here.txt of size 5 as ss9736m_was_here.txt (0.3 KiloBytes/sec) (average 0.8 KiloBytes/sec)
smb: \> get Burhan.txt
getting file \Burhan.txt of size 20 as Burhan.txt (1.0 KiloBytes/sec) (average 0.9 KiloBytes/sec)
smb: \> echo "APURBA SARKER - COMP1629" > APURBA_PROOF.txt
put APURBA_PROOF.txt
echo failed: NT_STATUS_IO_TIMEOUT
smb: \> put APURBA_PROOF.txt
APURBA_PROOF.txt does not exist
smb: \>
```

Figure C.3: Anonymous retrieval of multiple files confirming read access.

C.2 — Web Stack Enumeration

```

(apurba@192)-[~]
$ http -v GET http://192.168.100.107:8080/
GET / HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.107:8080
User-Agent: HTTPie/3.2.4

HTTP/1.1 200 OK
Accept-Ranges: bytes
Connection: keep-alive
Content-Length: 588
Content-Type: text/html
Date: Fri, 27 Mar 2026 21:52:13 GMT
ETag: "545675e8-24c"
Last-Modified: Sun, 02 Nov 2014 18:20:24 GMT
Server: nginx/1.4.0

<!DOCTYPE html>
<html>

<body>

<h1>bWAPP, an extremely buggy web app !</h1>

```

Figure C.5: HTTP 200 OK response disclosing outdated software stack: Apache/2.2.8, PHP/5.2.4, OpenSSL/0.9.8g

```

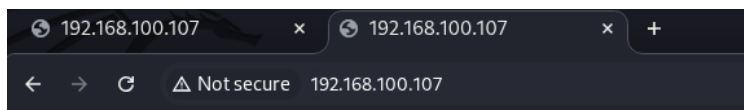
(apurba@192)-[~]
$ http -v GET https://192.168.100.107/ --verify=no
GET / HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.107
User-Agent: HTTPie/3.2.4

http: error: SSLerror: HTTPSConnectionPool(host='192.168.100.107', port=443): Max retries exceeded with url: / (Caused by SSLerror(
SSLerror(1, '[SSL: UNSUPPORTED_PROTOCOL] unsupported protocol (_ssl.c:1033)')) while doing a GET request to URL: https://192.168.1
00.107/

```

Figure C.6: HTTPS connection to 192.168.100.107 failing with “SSL: UNSUPPORTED_PROTOCOL”, confirming unsupported TLS/SSL configuration.

C.3 Exposed Directories & Vulnerable Applications



bWAPP, an extremely buggy web app !

[bWAPP](#)

[Drupageddon](#)

[Evil folder](#)

[phpMyAdmin](#)

[SQLiteManager](#)



Figure C.7: Root page exposing bWAPP, Drupal, Evil folder, phpMyAdmin, SQLiteManager.

```
(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.107/ \
-w /usr/share/wordlists/dirb/common.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/107_port80.txt

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.100.107/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.htaccess (Status: 403) [Size: 382]
.htpasswd (Status: 403) [Size: 382]
.hta (Status: 403) [Size: 377]
crossdomain.xml (Status: 200) [Size: 200]
crossdomain (Status: 200) [Size: 200]
drupal (Status: 301) [Size: 409] [→ http://192.168.1
00.107/drupal/]
evil (Status: 301) [Size: 407] [→ http://192.168.1
00.107/evil/]
index (Status: 200) [Size: 45]
index.html (Status: 200) [Size: 588]
phpmyadmin (Status: 301) [Size: 413] [→ http://192.168.1
00.107/phpmyadmin/]
README (Status: 200) [Size: 2491]
server-status (Status: 200) [Size: 22613]
```

Figure C.8: Gobuster enumeration revealing /drupal/, /evil/, /phpmyadmin/.

```

(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.107/ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/107_port80_deep.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.107/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

README (Status: 200) [Size: 2491]
index (Status: 200) [Size: 45]
INSTALL (Status: 200) [Size: 2589]
drupal (Status: 301) [Size: 409] [→ http://192.168.100.107/drupal/]
release_notes (Status: 200) [Size: 8271]
phpmyadmin (Status: 301) [Size: 413] [→ http://192.168.100.107/phpmyadmin/]
evil (Status: 301) [Size: 407] [→ http://192.168.100.107/evil/]
webdav (Status: 301) [Size: 409] [→ http://192.168.100.107/webdav/]
sqlite (Status: 301) [Size: 409] [→ http://192.168.100.107/sqlite/]
Progress: 87662 / 87662 (100.00%)

Finished

```

Figure C.9: Deep enumeration showing /webdav/, /sqlite/, /INSTALL/, /release_notes/.

```

(apurba@kali)-[~]
$ export WORKDIR=~/comp1629/task3/$IP

(apurba@kali)-[~]
$ arping -c 3 $IP | tee "$WORKDIR/scans/00_arping.txt"
arping: libnet_init(LIBNET_LINK, lo0): libnet_check_iface() ioctl: No such device
arping: you may need to run as root

(apurba@kali)-[~]
$ ping -c 3 $IP | tee "$WORKDIR/scans/00_ping.txt"
PING 192.168.100.111 (192.168.100.111) 56(84) bytes of data:
64 bytes from 192.168.100.111: icmp_seq=1 ttl=128 time=7.23 ms
64 bytes from 192.168.100.111: icmp_seq=2 ttl=128 time=6.90 ms
64 bytes from 192.168.100.111: icmp_seq=3 ttl=128 time=4.67 ms

— 192.168.100.111 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 4.669/6.268/7.233/1.138 ms

(apurba@kali)-[~]
$ nmap -Pn -n -T3 -sS --open --reason --top-ports 1000 \
-oA "$WORKDIR/scans/10_nmap_top1k_tcp" $IP

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 14:15 -0400
Nmap scan report for 192.168.100.111
Host is up, received arp-response (0.0074s latency).
Not shown: 994 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE REASON
135/tcp   open  msrpc   syn-ack ttl 128
139/tcp   open  netbios-ssn syn-ack ttl 128
445/tcp   open  microsoft-ds syn-ack ttl 128
903/tcp   open  iss-console-mgr syn-ack ttl 128
3389/tcp  open  ms-wbt-server syn-ack ttl 128
5357/tcp  open  wsddapi syn-ack ttl 128
MAC Address: 40:16:7E:A4:82:49 (ASUSTek Computer)

Nmap done: 1 IP address (1 host up) scanned in 4.92 seconds

```

Figure C.10: Complete Gobuster output confirming directory exposure.

6.4 Appendix D — Host 192.168.100.132 (nginx/Ubuntu)

```
(apurba@kali)-[~]
$ http -v GET http://192.168.100.132/login
GET /login HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.132
User-Agent: HTTPie/3.2.4

HTTP/1.1 404 Not Found
Connection: keep-alive
Content-Encoding: gzip
Content-Type: text/html
Date: Tue, 31 Mar 2026 14:47:43 GMT
Server: nginx/1.18.0 (Ubuntu)
Transfer-Encoding: chunked
```

Figure D.1

```
(apurba@kali)-[~]
$ http -v GET http://192.168.100.132/test
GET /test HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.132
User-Agent: HTTPie/3.2.4
```

Figure D.2

```
(apurba@kali)-[~]
$ gobuster dir \
-u http://192.168.100.132/ \
-w /usr/share/wordlists/dirb/common.txt \
-t 20 \
-o ~/Comp1629_Task03/gobuster/132_port80.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.100.132/
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

backup (Status: 301) [Size: 178] [→ http://192.168.100.132/backup/]
index.html (Status: 200) [Size: 640]
info.php (Status: 200) [Size: 21]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figure D.3

```

(apurba@kali)-[~]
$ http -v GET http://192.168.100.132/
GET / HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Host: 192.168.100.132
User-Agent: HTTPie/3.2.4

HTTP/1.1 200 OK
Connection: keep-alive
Content-Encoding: gzip
Content-Type: text/html
Date: Tue, 31 Mar 2026 14:46:25 GMT
ETag: W/"5f55b35b-280"
Last-Modified: Mon, 07 Sep 2020 04:13:15 GMT
Server: nginx/1.18.0 (Ubuntu)
Transfer-Encoding: chunked

```

Figure D.4

6.5 Appendix E — Host 192.168.100.126 (Tomato Router)

```

(apurba@kali)-[~]
$ curl -s http://192.168.100.126/ | head -n 20
<html>
<body bgcolor="white">
<head>
<title>Tomato</title>
<meta name="description" content="We Are Still Alive!">
<meta name="keywords" content="Potato">
<meta name="robots" content="index, follow">
<meta http-equiv="Content-Type" content="text/html; charset=utf-8">
<meta name="language" content="English">
</head>
<link href="https://fonts.googleapis.com/css?family=Righteous|Saira+St
"stylesheet">
<style type="text/css">
@font-face {
    font-family: 'Righteous', cursive;
    font-family: 'Saira Stencil One', cursive;
}
</style>
<center><br><br>
<br>
</center></body></html>

```

Figure E1: Tomato router UI disclosing Apache 2.4.18, nginx 1.10.3, firmware details.


```
(apurba@kali)-[~]
$ curl -I http://192.168.100.126/antibot_image/antibots
HTTP/1.1 301 Moved Permanently
Date: Mon, 30 Mar 2026 19:27:24 GMT
Server: Apache/2.4.18 (Ubuntu)
Location: http://192.168.100.126/antibot_image/antibots/
Content-Type: text/html; charset=iso-8859-1
```

Figure E.2: Directory listing of /antibot_image/.

```
(apurba@kali)-[~]
$ curl -s http://192.168.100.126/antibot_image/antibots/ | less

(apurba@kali)-[~]
$ curl -s http://192.168.100.126/antibot_image/antibots/ | grep -oP '(?<=href=")[^"]+'
?C=N;0=D
?C=M;0=A
?C=S;0=A
?C=D;0=A
/antibot_image/
antibot.php
assets/
dashboard/
functions/
guide/
info.php
language/
license.txt
readme.txt
screenshot-1.jpg
screenshot-2.jpg
screenshot-3.jpg
settings/
table/
uninstall.php
```

Figure E.3: Directory listing of /antibot_image/.

6.6 Appendix I — Burp Suite Web Application Testing

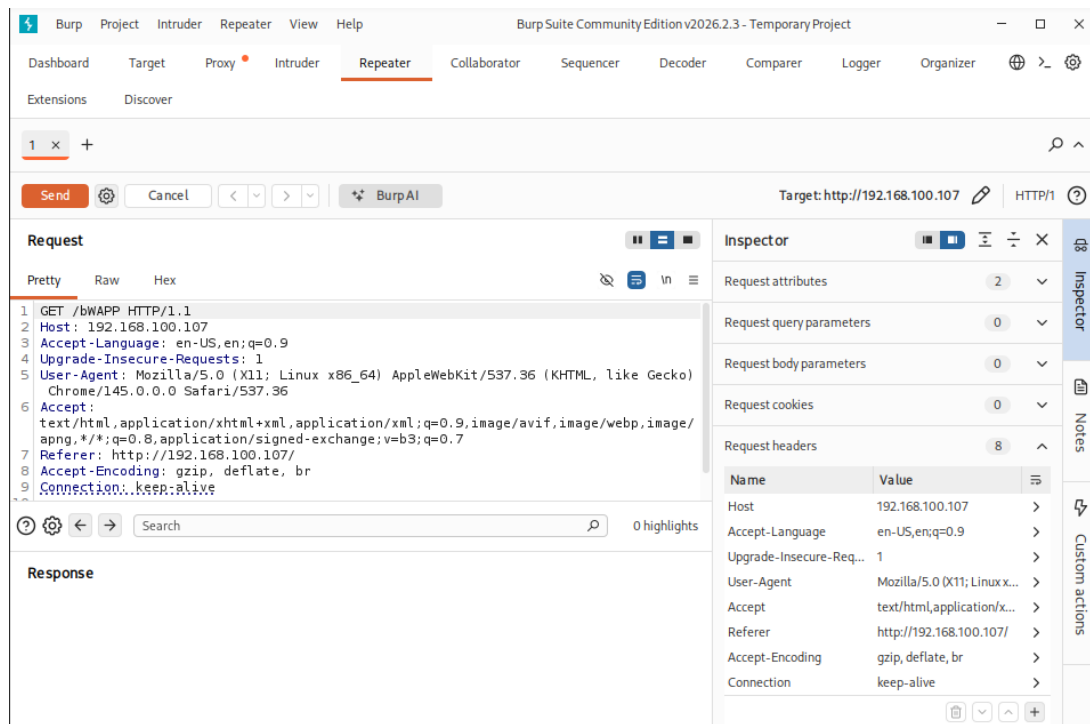


Figure F.1: Initial HTTP GET request intercepted in Burp Repeater.

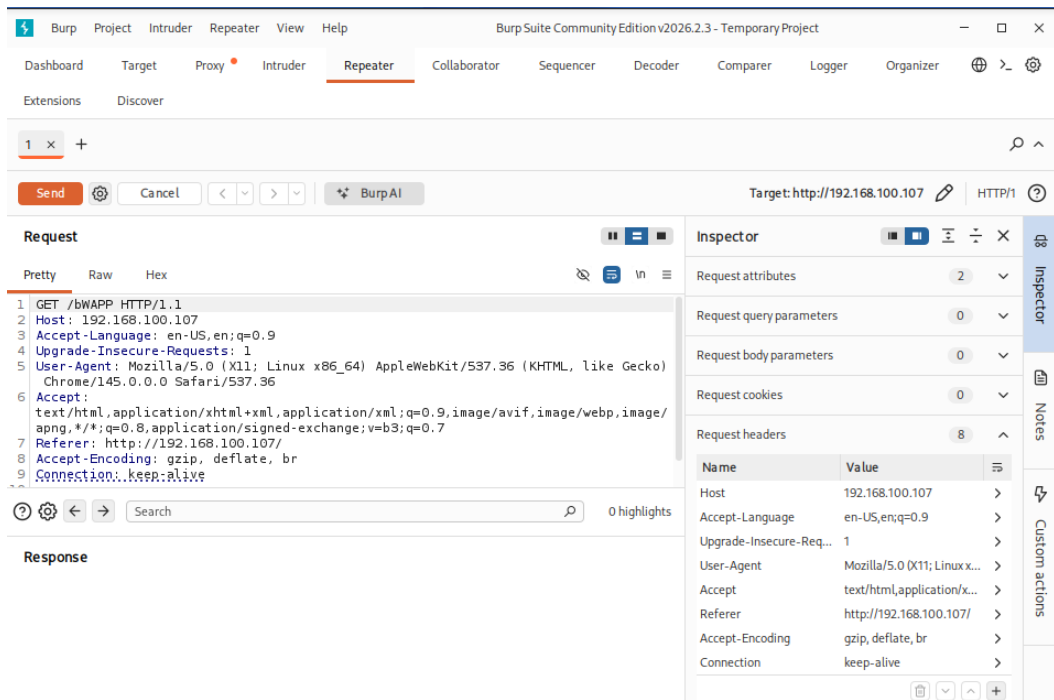


Figure F.2: Burp Suite request view.

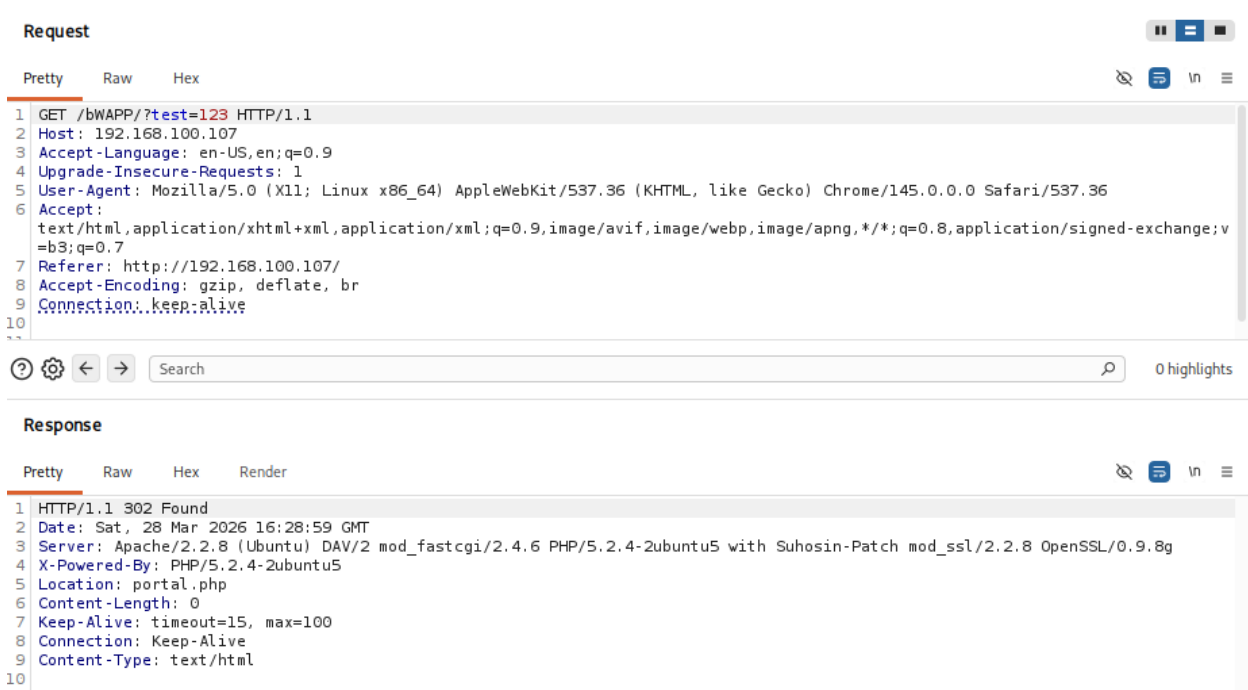


Figure F.3: Modified GET request used for parameter manipulation.

Conclusion:

The 192.168.100.0/24 environment penetration test revealed a series of security vulnerabilities in various hosts, and the risk was evidently concentrated in 192.168.100.107 (bee-box). Fourteen findings were recorded: 1 Critical, 3 High, 4 Medium, 3 Low and 3 Informational, which represents a rather weak security posture.

The worst problem was the Critical anonymous SMB write access on host 107 that allowed the system to be uploaded with files and was a complete compromise. High-severity vulnerabilities, such as old Apache/PHP/OpenSSL modules, depreciated nginx 1.4.0, and publicly accessible administrative and vulnerable applications, greatly widened the attack surface and made it easier to exploit. Medium-severe problems, including directory disclosure, unsupported TLS, and information leakage on HTTP headers, helped with reconnaissance and targeted attacks were easier. Less serious concerns such as verbose HTTP error messages, Telnet exposure and parameter manipulation acceptance, further undermined the defense posture of the environment. Other informational results showed hosts with limited services and unresponsive endpoints, which showed inconsistent configuration and asset management.

In general, the environment exhibits systemic vulnerabilities based on the use of outdated software, improperly configured services, and unneeded exposure of internal directories and insufficient access controls. The Critical and High issues, in particular, disabling anonymous access by SMBs, updating vulnerable software stacks, and limiting administrative panels should be remediated first, and the Medium and Low findings should be addressed to enhance defensive resilience. These measures will significantly minimize the exposure of the organization and enhance the maturity of the entire environment in terms of security.